

PIEDPIN

CISSP for BEGINNER

なぜCISSPを学ぶのか

- ✓ CISSP(Certified Information Systems Security Professional)とは、世界標準の**セキュリティ・プロフェッショナル認定**です。
- ✓ (ISC)²（国際情報システムセキュリティ認証コンソーシアム、International Information Systems Security Certification Consortium）が認定を行っています。
- ✓ 情報セキュリティ専門家が共通言語として利用している『(ISC)² CISSP CBK』を理解している者のみに与えられる資格です。
- ✓ 2004年6月に、米国規格協会（ANSI）より**ISO/IEC17024**の認証を受け、信頼度がより高くなりました。（https://japan.isc2.org/cissp_about.html）
- ✓ 2022年7月1日現在、日本のCISSPは**3,699**人となっています。（<https://japan.isc2.org/>）

(ISC)² が展開する資格ソリューション



国際的に認められた情報セキュリティ・プロフェッショナル認定資格です。米国規格協会（ANSI）よりISO/IEC17024の認証を受けた。



ベンダーフリー・カントリーフリーの情報セキュリティの資格です。情報セキュリティに従事しないが、組織を理解し、適切なコミュニケーションを行う。



クラウドサービスを安全に利用するために必要な知識を体系化した資格です。



ソフトウェアの脆弱性に端を発したセキュリティインシデントの増加や、政府や重要インフラにおけるセキュアなソフトウェアニーズに対応する資格です。

(ISC)² CISSP CBK ドメイン



ドメイン 1
セキュリティとリスク
マネジメント



ドメイン 2
資産のセキュリティ



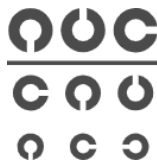
ドメイン 3
セキュリティアーキ
テクチャとエンジニ
アリング



ドメイン 4
通信とネットワー
クのセキュリティ



ドメイン 5
アイデンティティと
アクセスの管理



ドメイン 6
セキュリティの評
価とテスト



ドメイン 7
セキュリティの運用



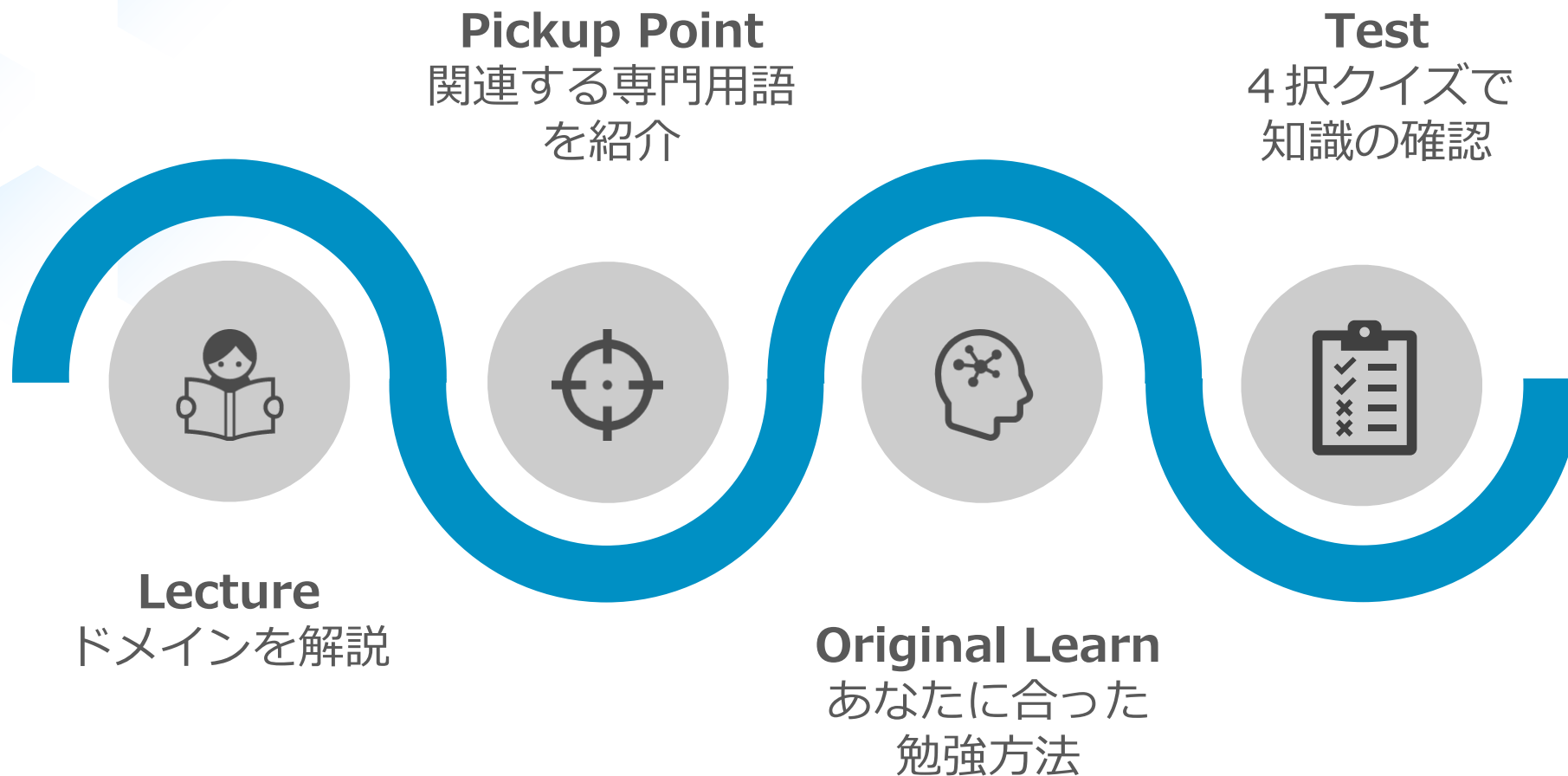
ドメイン 8
ソフトウェア開発
セキュリティ

あなたのゴールとレッスンの役割

- ✓ 情報セキュリティ初心者のために設計されたCISSP講座
経験者からすると“当たり前”と感じる内容も含まれます。
- ✓ 本レッスンの対象は、CBKのドメイン 7 です。
他のドメインのレッスンは対象外となります。
- ✓ CISSP合格のためのアップグレードが必要です。
現代のセキュリティの関心、流行、考え方を織り込みます。



レッスンの流れ



CISSP試験のドメイン別試験比重



ドメイン 1
セキュリティとリスク
マネジメント

15%



ドメイン 2
資産のセキュリティ

10%



ドメイン 3
セキュリティアーキテ
クチャとエンジニアリ
ング

13%



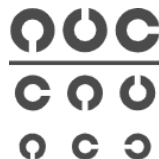
ドメイン 4
通信とネットワーク
のセキュリティ

13%



ドメイン 5
アイデンティティとア
クセスの管理

13%



ドメイン 6
セキュリティの評価
とテスト

12%



ドメイン 7
セキュリティの運用

13%



ドメイン 8
ソフトウェア開発セ
キュリティ

11%

DOMAIN 7 のカテゴリー



管理的コントロール

- 管理的コントロール



デジタルフォレンジック

- デジタルフォレンジック
- フォレンジックデータ



インシデント管理

- インシデント分類
- インシデント対応



異常検知

- 不正侵入監視
- 統合監視



運用管理

- システム運用
- 変更管理
- 運用脆弱性



耐障害性

- フォールトトレランス
- インフラ設備の冗長性

DOMAIN 7 のカテゴリー



事業継続計画

- 事業継続計画の策定
- ビジネスインパクト分析
- 災害対策環境
- 災害対策トレーニング



管理的コントロール

関連用語

- ジョブローテーション
- 必須休暇
- 強迫警報（Duress System）

管理的コントロール

管理的コントロール

● 管理的なセキュリティ管理

管理的コントロール

- ・ ガイドライン、教育などの組織制度によるコントロールです。

ジョブローテーション（ Job Rotation ）

- ・ ジョブローテーションとは、ある業務を定期的に持ち回ることであり、個人による不正を発見しやすくなり、共謀の可能性も低くする効果があります。
- ・ 従業員の燃え尽き防止や従業員が業務全体を理解するのに役立ちます。

強制的な休暇（ Mandatory Vacations ）

- ・ 従業員に強制的な休暇期間を設けます。
- ・ 不在の間に従業員のアカウントはロックし、アカウントの監査が行われます。従業員が不正を行っている場合にも監査で発見されます。
- ・ 副次的に、従業員の仕事へのストレスを緩和する効果も考えられます。



表：コントロールの種別

名前	内容	例
技術的コントロール	情報システムによるコントロールです。	ソフトウェア、ハードウェア、アクセス制御設定
物理的コントロール	物体によるコントロールです。	ドア、フェンス
管理的コントロール	組織制度によるコントロールです。	ガイドライン、教育

その解決策は有効？

試験において、あるセキュリティ対策に関して、その有効性を問われることもあるでしょう。ジョブローテーションなどの組織変更を行う戦略は経験則から経済的なメリットがないと判断し、その有効性を排除してしまいがちです。しかしながら、その有効性も否定できるものではありません。試験問題として、妥当な戦略であると考えられるのであれば、その有効性を否定すると危険です。

管理的コントロール

管理的コントロール



● 個人に対するセキュリティ

個人に対して通常セキュリティで保護されたアクセス制御や内部統制から逸脱した活動を強制される可能性があります。

強迫システム (Duress System)

- 強迫警報/強迫システムは、人を追跡するために使用されるモバイルデバイスです。
- 人々の所在を追跡したり、もしくは精神的にも危険な状況にあるときの警告として使用できます。
- 危険地域への出入りを警告したり、ストレスとなるような状況で押す緊急ボタンを用意することが検討されます。

旅行先でのネットワーク利用

- 社内では意識せずとも安全な環境が提供されているでしょう。
- そのため、旅行先ではセキュリティの意識が追いつかない可能性があります。
- 旅行先での無料Wi-Fiは機密情報の漏洩のポイントです。いざという場合にインターネットの利用を提供してくれますが、端末内の情報を盗み取られる可能性があります。



強迫システム

(<https://www.guard1.com/solutions/personal-alarms/>)

デジタルフォレンジック

関連用語

- デジタルフォレンジック
- 電子的証拠開示 (e-discovery)
- 証拠保全 (Chain of Custody)
- 割り当てられた領域 (Allocated space)
- 不良セクター/クラスター/ブロック
- Catch-it-as-you-can
- Stop, look and listen

デジタルフォレンジック

デジタルフォレンジック

● デジタルフォレンジックとは

- デジタルフォレンジックとは、コンピュータ犯罪の解決に向け、デジタルデバイスから発見されたデータの証拠の適切な収集と保護です。
- デジタルフォレンジックとしてデータを収集する対象となるのは、ほとんどの電子記憶媒体が該当します。
- デジタルデータは、時間とともに消滅するリスクも大きくなります。



デジタルフォレンジック

デジタルフォレンジック



●デジタルフォレンジックの目的

現場の情報システムのデジタルデータを証拠として保存し、裁判などで必要になった時のために、証拠能力を証明します。

機密情報が漏洩した場合には、持ち出された経路、情報漏洩の範囲、持ち出したのか人物の特定するなど、捜査もしくは裁判に必要な情報を情報技術を用いて明らかにします。

●プライバシー

合法的な方法で証拠を入手しなければなりません。不当な搜索と押収によって、人、家、書類、および所持品の安全を確保するという人民の権利は侵害されてはなりません。（米国憲法の修正第4条）企業や国が定めたプライバシーについてのルールに準拠するとともに、裁判所の指示に従うべきです。



収集

- 証拠の確保
- メディアのコピー

ディスクに対しては物理コピーを行います。その際、コピー元とコピー先に対してデジタル署名を取り、同一性を担保します。



検査

- 解析用データへの変換

暗号化データを復号するなど解析用データ形式に変換します。



分析

- 正確な情報の分類

ファイルデータの分類、データファイルの解析を実施する。



報告

- 調査結果の整理
- 正当な調査の証明

法廷などにおいて必要となるレポートを作成する。事実を簡潔に記載する。

デジタルフォレンジック

デジタルフォレンジック

SD

●フォレンジックの保存プロセス

情報の収集

- 攻撃者は、証拠となるようなログを削除して痕跡を消すように工夫します。
- フォレンジックデータは通常、揮発性の高いものから揮発性の低いものへと作業を進め、RAMから始めてハードディスクで終わらせます。
- 証拠の完全性を疑われないようにすることが重要です。フォレンジックはオリジナルではなくコピーに対して行われますが、フォレンジックの前と後にオリジナルとコピーの両方のハッシュが等しいことを確認します。

情報の保全

- 証拠保全（Chain of Custody）とは、証拠としてみなされ続けるように安全に保管するために、誰がいつそれを持っていたのか？何が行われたのか？いつ行われたのか？を文書化する事です。



CHAIN OF CUSTODY		
Received from		
By		
Date	Time	AM/PM
Received from		
By		
Date	Time	AM/PM
Received from		
By		
Date	Time	AM/PM
Received from		
By		
Date	Time	AM/PM
Received from		
By		
Date	Time	AM/PM

どのように保管されてきたのか詳細を記載しておく。

証拠保全（Chain of Custody）によって随時記録される

デジタルフォレンジック

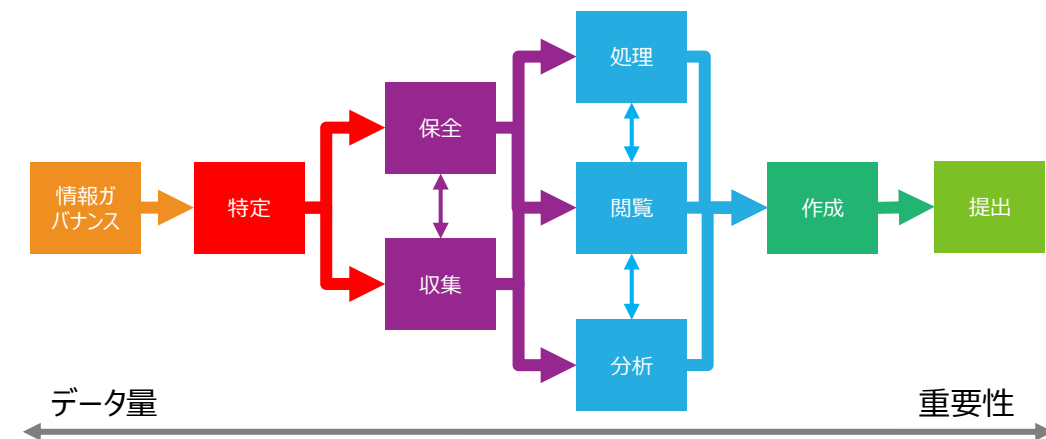
デジタルフォレンジック



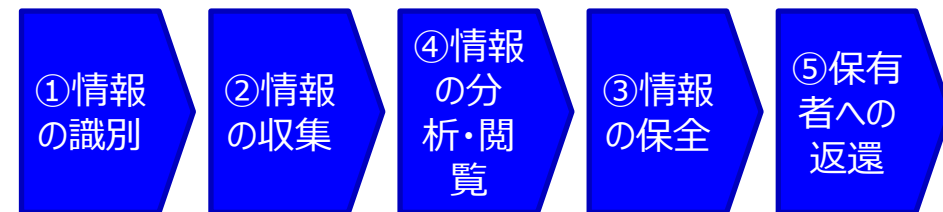
● e-Discovery（電子証拠開示）

e-Discovery

- e-Discoveryとは、法的手続き、訴訟、政府の調査、または情報公開法の要請において、電子形式の情報を開示する手続きのことです。
- 紙の情報とは、その無形の形態、量、一過性、永続性のために異なると考えられています。一方で、紙の文書にはないメタデータが添付されており、証拠として重要な役割を果たすことがあります。
- 電子文書のメタデータを保存するには、証拠隠滅を防ぐための特別な課題があります。e-Discoveryの対象となる電子データは、Office文書、電子メールにいたるまであらゆるデータが含まれるため、データの保管だけで膨大な量になります。よって、ひとたび訴訟に巻き込まれると、整理などに膨大な作業を被ることになります。



e-Discoveryプロセス



e-Discoveryの開示プロセス

デジタルフォレンジック

フォレンジックデータ



● ディスク・フォレンジック

ディスクパーティション

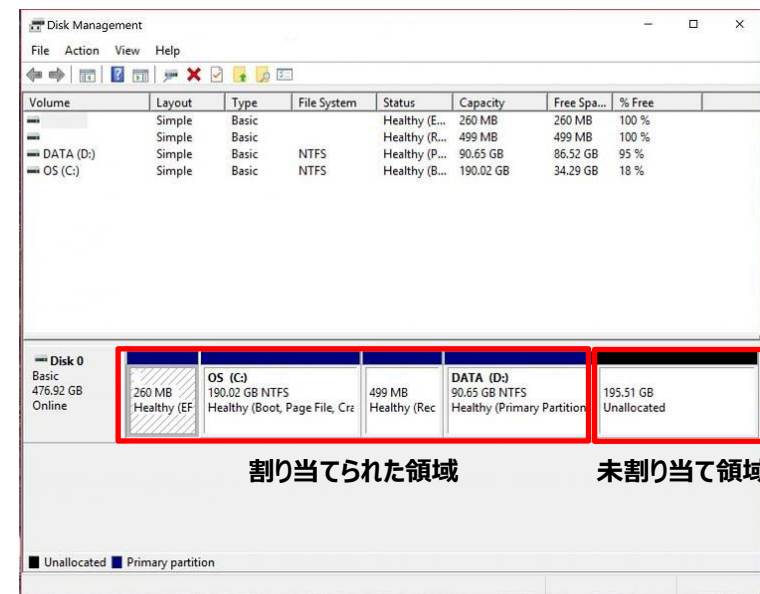
- 文章ファイルやログなどのデータを物理的に記録する場所はディスクです。
- ディスクを追加するということは、ディスクのどの程度のデータ区域をどのファイル群（ドライブ）を割り当てるのかを決めています。
- 例えば、アプリログが異常に書き込まれ、OSやアプリ本体が動かなくなるとは困ります。OS用、アプリ用、アプリログ用として利用できるデータ容量を区切っていけば安心です。

割り当てられた領域（Allocated space）

- 割り当てられた領域とは、ディスクの中でデータが存在するとマークされている部分です。

未割り当て領域（Unallocated space）

- 未割り当て領域とは、ディスクの中でアクティブなデータが含まれていないディスクの部分です。



Windowsのディスク割り当て管理画面

デジタルフォレンジック

フォレンジックデータ



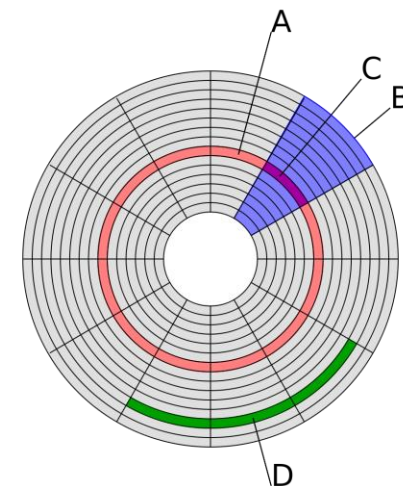
● ディスク・フォレンジック

スラックスペース

- スラックスペースとは、クラスターと利用しているデータの間の余剰スペースです。
- データは、クラスターと呼ばれる特定のサイズの塊で保存されます。そのため、クラスターの一部の情報を使わなくなったからといって、その分が解放されるわけではありません。
- スラックスペースには、古いデータが含まれていたり、攻撃者が情報を隠すために使用されることがあります。

不良セクター/クラスター/ブロック

- 不良セクターとは、ディスクの中で物理的な欠陥のために読めないスペースです。
- ディスクの一部が物理的な破損などにより読み取れない場合、そのセクターは“不良”としてマークします。
- “不良”とマークされたセクターはデータが読み取れないため、オペレーティングシステムによって無視されます。
- 攻撃者は、セクターなどを“不良”とマークして、ディスクのこの部分にデータを隠すことができます。



A : トラック
B : セクター
C : トラックセクター
D : クラスター

ディスク構造

([https://ja.wikipedia.org/wiki/%E3%82%AF%E3%83%A9%E3%82%B9%E3%82%BF_\(%E8%A8%98%E6%86%B6%E5%AA%92%E4%BD%93\)\)](https://ja.wikipedia.org/wiki/%E3%82%AF%E3%83%A9%E3%82%B9%E3%82%BF_(%E8%A8%98%E6%86%B6%E5%AA%92%E4%BD%93))))

デジタルフォレンジック

フォレンジックデータ



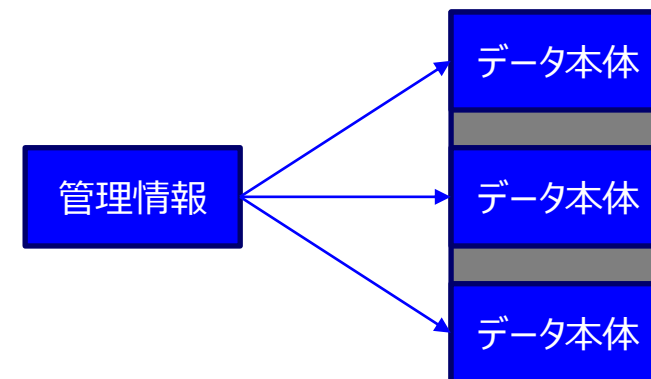
●ディスク・フォレンジック

メモリ・フォレンジックとは、メインメモリ上のデータをダンプなどの行った後、解析する手順や技術です。

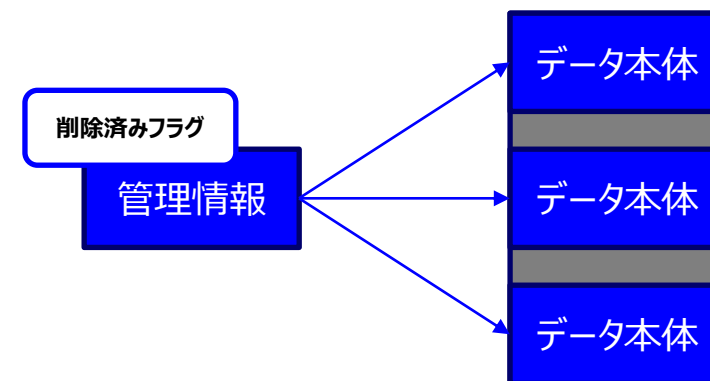
具体的には、攻撃者はマルウェアを揮発性メモリに配置するようにし、電源を切るとマルウェアが消すことで証拠を残らないようにします。そのため、攻撃を受けた時には早期にシャットダウンするのではなく、起動し続けても安全と思われる場合は、ネットワークから切断してメモリデータを起動状態を維持しながらコピーしていきます。

ごみ箱を空にしても安全ではない

- コンピュータ上のファイルは、連続した位置に保管されているわけではなく、物理的には断片化されディスクの各所に保管されています。あなたがファイルを開いた際には、まずデータの所在を示した管理情報を確認して、HDD上のデータを拾い集めてきて、一つのまとまったファイルデータに見せています。
- あなたがデスクトップの「ごみ箱」に入れて削除したときには、この管理情報が“再利用可能な状態”にしかたけです。つまりは、再利用可能であるが、まだ実際再利用されていない管理情報があれば、ごみ箱から削除されようと復元ができます。



ごみ箱から削除



デジタルフォレンジック

フォレンジックデータ

SD

●ディスク・フォレンジック

データカービング

- ファイルデータの固有のビット配列を頼りに、HDDからファイルデータを復元する方法です。
- 管理情報が上書きされてしまった場合には、HDDのどこにデータがあるかわからなくなります。しかし、画像データなどのファイル形式ごとに先頭のビット列は固有であるものがあります。この固有のビット列を検索し、そこから連続しているデータを確認すれば、ファイルデータを管理情報なく復元できます。
- ただし、ファイルデータはディスクに保存される際には断片化されていますから、一部分だけ復元できることを期待します。

SSDではデータ復元が難しい

磁気ディスク（HDD）と半導体メモリ（SSD）のフォレンジックの観点での違いがあります。HDDではディスクのデータがある場所に新しいデータを上書きできますが、SSDではできません。よって、HDDでは新しいデータが利用するまでデータを残留している可能性があります。SSDでは削除されたタイミングで元のデータを消去する必要があり、データの復元力がありません。HDDでは削除前のデータが残っていることがありますが、SSDでは復元はより難しくなります。

デジタルフォレンジック

フォレンジックデータ

●ネットワーク・フォレンジック

ネットワーク・フォレンジック調査では、揮発性ある動的な情報を扱います。ネットワークトラフィックはマシン間のリクエストの介在しており、ネットワークフォレンジックはしばしば積極的な調査をします。

ネットワークに異常なトラフィックがないかを監視し、侵入者を特定します。攻撃者は侵入したホストのログファイルをすべて消去することを検討します。ネットワークベースの証拠が、フォレンジック分析に利用できる唯一の証拠となるかもしれません。

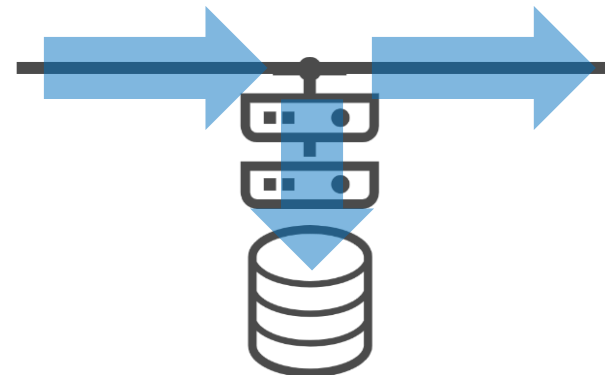
キャプチャしたネットワークトラフィックの分析には、転送されたファイルの再構成、キーワードの検索、電子メールやチャットセッションなどのコミュニケーションの解析などの作業が含まれます。

Catch it as you can (できる限りキャッチ)

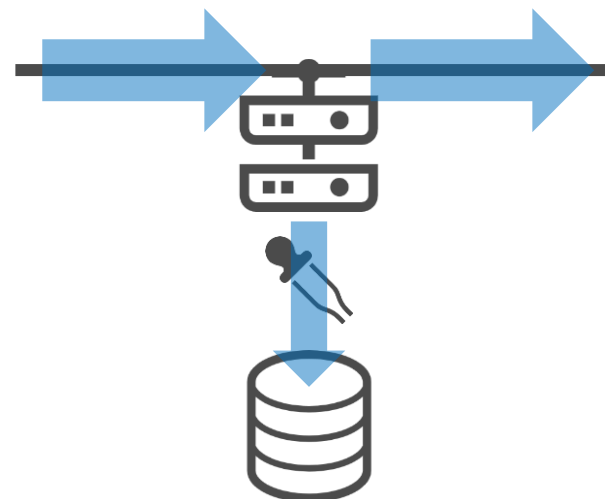
- ネットワークトラフィックの収集の一つであり、特定のトラフィックポイントを通過するすべてのパケットをキャプチャしてストレージに書き込み、その後バッチモードで解析を行うことです。
- すべてのリクエストを保管するほどの大容量のストレージが必要になります。

Stop, look and listen (止めて、見て、聞く)

- ネットワークトラフィックの収集の一つであり、各パケットはメモリ上で基本的な方法で解析され、特定の情報のみが将来の解析のために保存される方法です。
- 各トラフィックを分析していくために、より高速な処理性能が必要となります。



Catch it as you can



Stop, look and listen

デジタルフォレンジック

フォレンジックデータ

SD

●モバイル・フォレンジック

携帯端末やスマートフォンのような無線を用いて通信する機器に対するデジタルフォレンジックです。

昨今では、IoT（Internet Of Things）がセキュリティ上の懸念材料になり得ます。すべてのデバイスには豊富な情報が詰まっています。

GPSは、車、電話、人がある時間にどこにいたかを示していますし、エアコンの電源が入っているか時間情報は、その時間に誰かが家にいたかを推定することができます。フォレンジック調査員は、調査において、組み込みデバイスにアクセスし、解釈し、分析する能力が必要になってくるでしょう。

●ソフトウェア・フォレンジック

ソフトウェアのフォレンジック解析は、ソフトウェアの比較やリバースエンジニアリングを行うことです。

捜査官は、マルウェアプログラムのバイナリコピーを入手し、何をしているのかを推測しようとしています。

試験のテクニック

リバースエンジニアリングは、ソフトウェアの解析です。つまり、ソフトウェア・フォレンジックは知的財産権の侵害を指すこともあるのでは？と思ったかもしれませんが、試験の中ではこのような前提がない限りは、正義のフォレンジックのために実施しているものと判断してよいでしょう。



インシデント管理

関連用語

- インシデント
- インシデントの分類（自然・人間・環境）
- 根本原因分析

インシデント管理

インシデント分類

● インシデント

システム障害は組織によって定義が違ふものの、リリース後のシステムにおいてユーザー業務に影響が出ている恐れのあるものを指すでしょう。システム障害を検知するために、サーバーのダウンやネットワーク接続の状態を確認することになりますが、サーバーがダウンしているからシステム障害であるということは本質的には、より広い視野を持つべきです。

イベント

- ・ イベントとは、観察可能な状態の変化を指します。これはネガティブでもポジティブでもなく、ただ何かが変化したということです。
- ・ システムの電源投入、あるセグメントから別のセグメントへのトラフィック、アプリケーションの起動などがこれに当たります。

警告

- ・ 通常の状態ではないことを示し、インシデントにつながる可能性を事前に通知します。
- ・ 特定のイベントが発生した場合に警告を発します。「トラフィック使用率が75%以上、メモリ使用率が90%以上の状態が2分以上続いた場合」などが該当します。



試験のテクニック

インシデントは本来は資産への障害を示す広範囲を示す言葉ですが、試験の中ではインシデントという場合、コンピュータ資産、ネットワーク、情報システムなどのシステムインシデントを指していると考えてよいでしょう。地震やヒューマンエラーまで加味すると考えることが多くなって、必要以上に体力を使ってしまうですよ。

インシデント管理

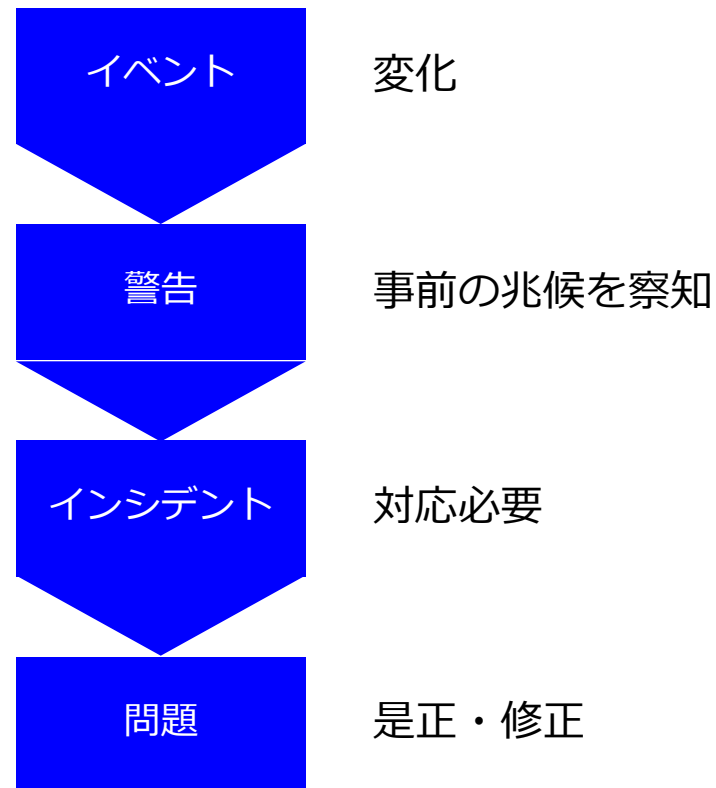
インシデント分類

● インシデント インシデント

- インシデントとは、機密性・完全性・可用性に関わる悪影響を及ぼす事象です。システム上のイベントを監視・検知し、それらのイベントにどのように対応するかをインシデント管理が必要です。
- インシデント対応では、スタッフが何をすべきかを正確に把握し、継続的なトレーニングを受け、手順を理解していることが重要です。

問題

- 問題とは、原因不明のインシデントであり、インシデント対応と同様のステップを踏むことになります。
- 根本原因分析にはより多くの時間が費やされ、何が起こったのかを知ることで二度と起こらないようにする必要があります。



インシデント管理

インシデント分類

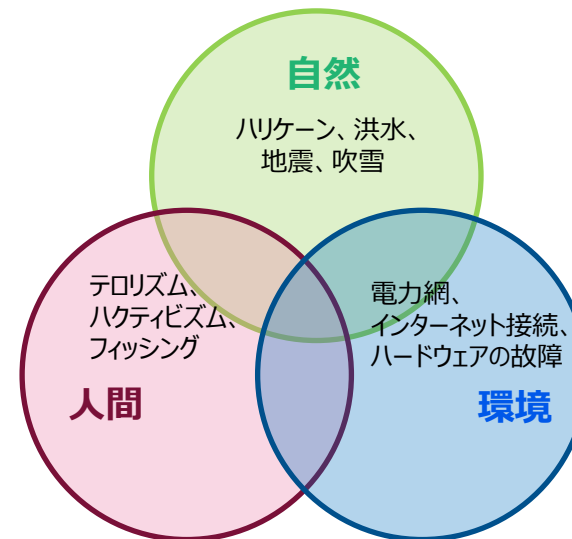
● インシデントの分類

インシデントの分類

- “自然”とは、ハリケーン、洪水、地震、吹雪など、自然に起因するものです。
- “人間”とは、テロリズム、ハクティビズム、フィッシングなど、人間が意図的または無意識に行うヒューマンエラーです。
- “環境”とは、電力網、インターネット接続、ハードウェアの故障、ソフトウェアの欠陥など私たちが働いている環境に起因するものです。

インシデントの影響規模

- 無災害（ Non-Disaster ）とは、非破壊的な障害、ハードディスクの故障、クラスター内の1つのサーバーがダウンなどです。
- 緊急（ Emergency ）とは、緊急を要する人命や財産を失う可能性のある事象です。
- 災害（ Disaster ）とは、当社の施設全体が24時間以上使用できない状態です。
- 大惨事（ Catastrophe ）とは、施設が破壊された状態です。



インシデント原因分類

インシデント管理

インシデント対応

●インシデント対応

①準備（Preparation）

- ・ インシデントに備えるために行うステップです。
- ・ ポリシーや手順を作成、検知ソフトやハードウェアを調達など、インシデント対応チームに必要なツールを提供します。

他の教材では見たインシデント対応プロセスと異なる？

教材によってインシデント対応のプロセスは異なるでしょう。ITILベースのインシデント対応では、イベント管理→インシデント管理→問題管理というより大きなくりで表現されますし、ICS（Incident Command System）ベースのインシデント対応では、トリアージ→緩和→解決→フォローアップというくりになります。ここでは、ほかのフレームを提示された場合であっても概要がわかるように、最も細かいレベルで説明いたします。



①準備（Preparation）

②検知（Detection）

③隔離（Response）

④根絶（Mitigation）

⑤報告（Reporting）

⑥復旧（Recovery）

⑦修復（Remediation）

⑧教訓（Lessons Learned）

インシデント管理

インシデント対応

●インシデント対応

②検知 (Detection)

- ・ イベントを分析して、それがセキュリティインシデントであるかどうかを判断します。
- ・ イベントを早期に検知すればするほど、早期に対応・解決することができます。
- ・ IDS (Intrusion Detection System) による検知と、IPS (Intrusion Prevention System) による検知とさらなる侵害の防止を行います。
- ・ 初動のタイミングで確認すべきポイントがあります。どのサービスのエラー画面か、いつから発生しているか、現在も続いているか、どのような操作をしたのか、過去にも事象があるか、特定のユーザーにのみ発生するのかなどを聞き出しておくといでしょう。

聞き出すポイント (例)	理由
どのサービスの画面か？	問題箇所の特定、どのシステム担当に連絡するべきかの判断。
いつから発生しているか？	特定時刻のログを取得する必要があります。
現在も続いているか？	ユーザー影響、通知するべきかを確定させる。
どのような操作をしたのか？	原因調査のため、具体的に発生させる手順を確認する。
過去にも事象があるか？	既知の問題であれば、現在原因調査をする必要がありません。
特定のユーザーにのみ発生するのか？	ユーザー環境によるものか、システムによるものかを切り分けることができます。



①準備 (Preparation)

②検知 (Detection)

③隔離 (Response)

④根絶 (Mitigation)

⑤報告 (Reporting)

⑥復旧 (Recovery)

⑦修復 (Remediation)

⑧教訓 (Lessons Learned)

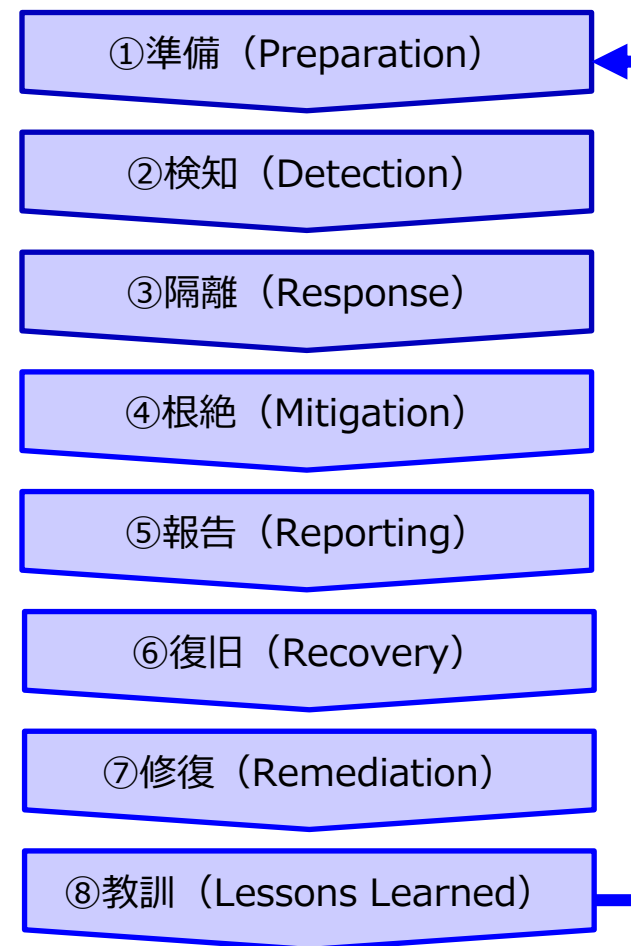
インシデント管理

インシデント対応

● インシデント対応

③ 隔離 (Response)

- インシデント対応チームが影響を受けたシステムを調査し、インシデントの結果としてさらなる被害が発生しないようにします。
- システムをネットワークから切り離す、トラフィックを隔離する、システムの電源を切るなど、インシデントの範囲と深刻さの両方を最小限に抑えるために、計画に基づいてシステムを隔離します。
- なお、Responseの辞書的な日本語訳は“対応”となりますが、“対応”という言葉では本プロセスの目的が不明瞭になること、かつ本プロセスの主たる目的は現問題からの封じ込めであることから本資料では日本語の“隔離”という言葉を使わせて頂いております。他の教材と差異がある可能性がありますので、ご了承ください。



インシデント管理

インシデント対応

●インシデント対応

④根絶（Mitigation）

- ・ インシデントの原因を理解し、後の復旧段階でシステムを確実にクリーンアップして運用状態に戻せるようにします。前フェーズのResponseとの違いは根本的な原因の解決になります。
- ・ システムへの明白な侵入経路を取り除いたとしても、攻撃でインストールされたバックドアやその他のマルウェアを見逃している可能性もあります。
- ・ 侵害されたシステムを解決する一つの方法としてリストアが考えられますが、バックアップに侵入経路がないことを確証するためには、根本原因分析を行う必要があります。侵入以降のバックアップをリストアしても意味がありません。
- ・ 既知の脆弱性によるものであれば、セキュリティパッチを当てます。新たに発見された脆弱性であれば、再び外部に公開する前に緩和策を検討してください。

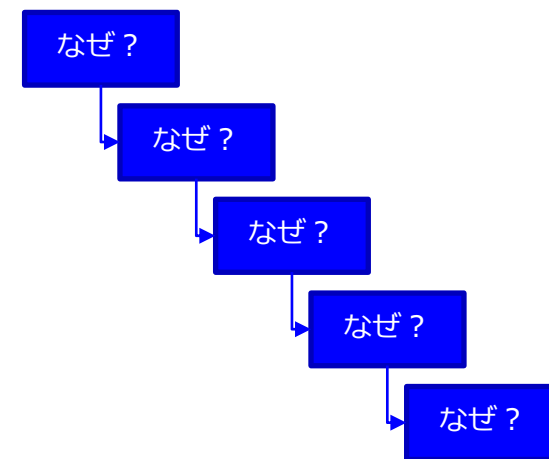
根本原因分析

- ・ 根本原因分析では、インシデントを発生させた根本的な弱点や脆弱性を明らかにします。根本原因分析を行わなければ、同じ問題に再び直面する可能性が高いです。
- ・ 影響を受けたシステムだけでなく、特定の脆弱性や一連の脆弱性を持つ組織内のあらゆるシステムの脆弱性を修正する必要があります。例えば、脆弱なパスワードポリシーや暗号化がシステム侵害の根本的な原因となっている場合、その脆弱性を取り除くために対策を講じることになります。



なぜなぜ分析

根本原因分析の手法の一つになぜなぜ分析というものがあります。なぜなぜ分析とは、トヨタ生産方式の一つであり、問題を発見したら“なぜ？”を5回繰り返すというものがあります。これにより、今まで見えてこなかった原因が現れてきます。さすがトヨタですね。



インシデント管理

インシデント対応

●インシデント対応

⑤報告（Reporting）

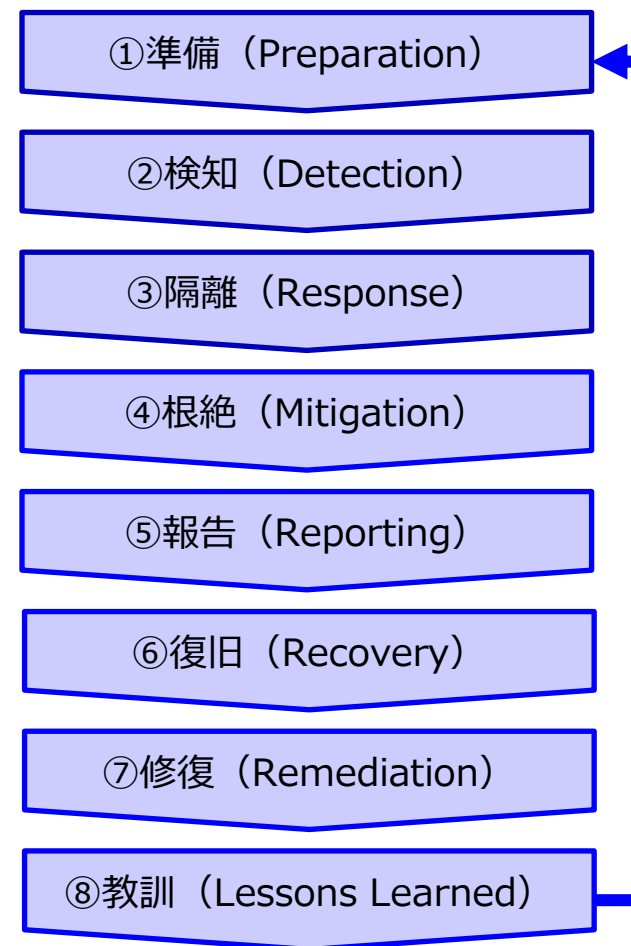
- 原因調査できた事象を分かりやすく説明するレポートを作成します。
- 重大なインシデントについては経営陣にも通知します。経営陣は必要に応じて法務部、広報部など他の部署と協力することを許可します。
- 報告には、システム要件などの技術的なものとヒューマンエラーや体制などの非技術的なものがあります。

⑥復旧（Recovery）

- システムを通常運用可能な状態に復旧します。
- 最新のデータの復旧、ACL（アクセスコントロールリスト）が適切か、不要なサービスが上がっていないかなどをダブルチェックし、通常稼働に戻します。

⑦修復（Remediation）

- システムの脆弱性と解決策を横展開し、システム全体としてのリスクを緩和します。
- 同じ脆弱性を持つ可能性があるすべてのシステムにパッチや改善を要請するなど、より広範な修復が行われます。



インシデント管理

インシデント対応

●インシデント対応

⑧教訓 (Lessons Learned)

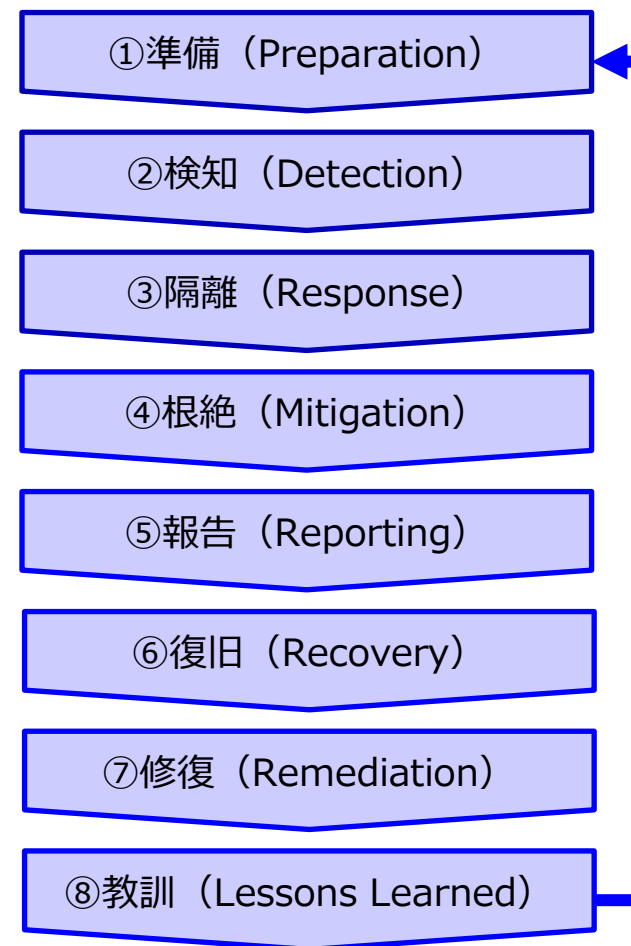
- ・ インシデント対応についての問題を解決し、新たな管理や保護措置を導入します。
- ・ どのようにうまく対処したか、何がうまくいって何がうまくいかなかったのか。次回別の問題が発生したときに組織としてどのように成長し、より良くなることができるでしょうか。
- ・ 最終的にシニアマネージャーに報告し、最終責任者はシニアマネージャーになります。

教育の手法

障害発生後には、新人にも問題の本質を理解いただき、将来同じような問題が起きた際にも解決への探求力をつけさせなければなりません。
体系的な学習も勿論、手順を修正するように依頼すると、今までの手順の見直しを頂く機会にもなります。

代表的な教育手法

- ・ 体系的な学習計画
- ・ シャドーイング
- ・ 検証機を使った実機復旧
- ・ ジョブローテーション
- ・ 運用手順書の修正





異常検知

関連用語

- フェールセキュア
- 侵入検知システム（IDS、Intrusion Detection System）
- 侵入防止システム（IPS、Intrusion Prevention System）
- シグネチャ（パターン）マッチングベース検知
- ヒューリスティック（行動）ベース検知
- 警告バー（Warning Banner）
- SIEM
- サンプルング
- SOAR
- ハニーポット
- ハニーネット
- サンドボックス
- スレットインテリジェンス
- セキュリティ侵害インジケーター
- ログハンドリング

異常検知

不正侵入監視

● 監視環境

システム異常を検知するためには監視したい事象に合わせた監視モジュールが必要です。

企業のようにITサービスを継続して展開する場合には、アプリケーションのログの情報だけを監視対象とするのは無理があります。たとえ、アプリケーションのログが出力されない場合には、アプリケーション自体が止まっているケースやそもそもアプリケーションに通信が到達していないケースもあり、システムで起こっているすべての事象がアプリケーションのログに現れるわけではないからです。

ネットワークが十分であるか、負荷が多くなりサーバー単体でのリソースが枯渇しないかも合わせて監視していかなければなりません。

また、監視モジュールによっては監視する事象がかぶってしまうこともあります。何をどの監視モジュールで検知するのかは過度な検知にならないように取り決めが必要です。



種類	監視モジュール例
アプリケーション監視	APM
サーバー監視	CPU、メモリ、ディスク使用量
ネットワーク監視	SNMP、フロー監視
セキュリティ監視	auditd、IDS、IPS

異常検知

不正侵入監視



●ネットワークでの不正侵入監視

セキュリティネットワークでは、侵入検知システム（IDS）と侵入防止システム（IPS）の両方を使用して、悪質と思われるトラフィックを捕捉し、警告またはブロックしています。

侵入検知システム

- 侵入検知システム（IDS、Intrusion Detection System）とは、システム監視を行い、受動的なアクションにつなげる機構です。
- イベントが発生するとアラートが出し、管理者に通知されます。

侵入防止システム

- 侵入防止システム（IPS、Intrusion Prevention System）とは、悪意のあるトラフィックに対してアクションを起こします。
- イベントがトリガーとなり、トラフィックの破棄やリダイレクトを行います。また、監視や管理者の通知と組み合わせられることもあります。

入る道あれば、出る道あり

不正な操作を“侵入”とイコールと思いがちです。しかし、不正な操作は入口だけではなく、出口も見えておかなければなりません。もしも、サボタージュなどの理由により機密情報が外部に漏れ出るアクセスがあった場合、これを抑止しなければなりません。社内ネットワークから外部へのアクセスを監視することを出口監視（Egress Monitoring）と言います。

異常検知

不正侵入監視



● 検出条件

シグネチャ（パターン）マッチングベース検知（Knowledge-Based Detection）

- シグネチャ（パターン）マッチングベース検知は、既知の悪意のあるトラフィックパターンと一致しているかを照合します。
- トラフィックを悪意のあるパターンと照合するだけであるためより高速です。ただし、ゼロデイ攻撃に弱く、新しい脆弱性パターンに対応するためには常に更新する必要があります。

シグネチャ（パターン）マッチングベース検知



ヒューリスティック（行動）ベース検知（Behavior-Based Detection）

- ヒューリスティック（行動）ベース検知は、「異常とみられる行動」を活動を検出することです。
- パターンが一致しなくとも異常な行動という条件で検知されるため、比較的新しい・未対応の脆弱性に対しても検知が望めます。
- シグネチャーマッピングベースとヒューリスティックベースの両方でチェックすることが望めます。

ヒューリスティック（行動）ベース検知



クリッピングレベル

- クリッピングレベルは、データ抽出ではありますが、ある閾値を指します。したがって、統計的な算出を目的とした抽出ではありません。



異常検知

不正侵入監視

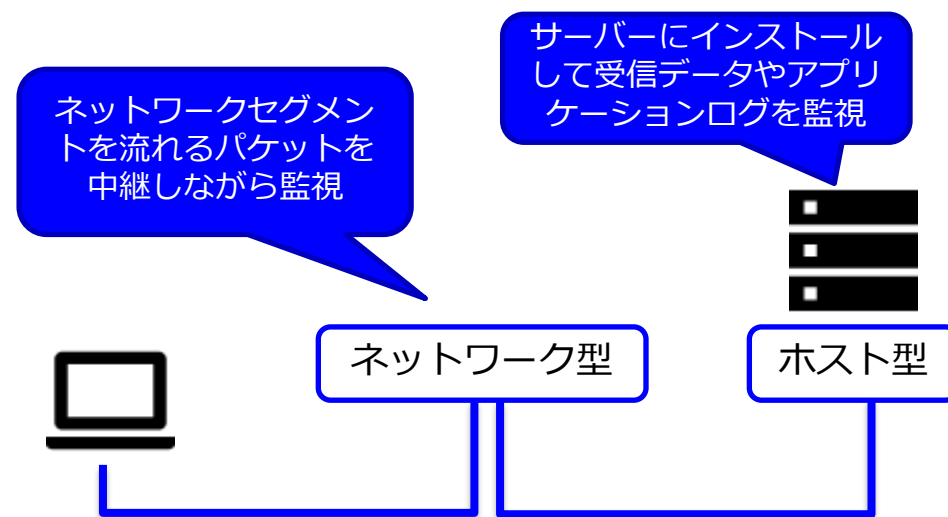
● 設置場所

ネットワークベース (Network-Based)

- 監視モジュールがネットワークセグメント（スイッチポートなど）に設置される構成を指します。
- 送信先のポート、IP、プロトコル、トラフィックのコンテンツを検査しますが、暗号化されたトラフィックは検査できません。
- 1台のスイッチに導入する場合、ポートとNICはプロミスキャスでポートはスパンポートである必要があります。

ホストベース (Host-Based)

- 監視モジュールがクライアント（サーバーやワークステーションなど）に設置される構成を指します。
- トラフィックの他、サーバーリソースの使用状況や特定のアプリケーション処理に併せて確認することができます。



異常検知

不正侵入監視

● 侵入マスキング

フラグメンテーション

- 断片化されたパケットを送信することで、検知される時点では分割されたパケットとなることで攻撃のシグネチャの検知を回避しようとしています。

アドレスの偽装

- 悪意のある送信を識別するために送信元アドレスが利用されます。
- しかし、攻撃者は、セキュリティの低いプロキシサーバを使用して送信元を偽装し、IDS・IPSが攻撃の送信元を検出することを困難にします。

パターン変更回避

- マルウェアが異なる文法で同じ処理をさせるが不要なデータを付属するなどして、パターン検知を回避しようとしています。



True Positive
(本当の攻撃を検知する)



True Negative
(本当の攻撃を検知しない)



False Positive
(偽の攻撃を検知する)



False Negative
(偽の攻撃を検知しない)



検知の分類はパターンは4つに分類される

異常検知

不正侵入監視

● 不要な検知の減少方法

警告バー（Warning Banner）

- システムが異常の挙動として検知するのは、100%悪意のあるユーザーによるものではありません。善意によるユーザーが意図しない操作によって、システムが異常と検知することもあります。
- 善意のユーザーの意図しない操作によって生じる検知を抑止するためには、警告画面を表示する事が有効です。
- 積極的なアプローチでは、警告以降の操作を監視することを通知します。



不正な操作については、ユーザーに知らせることも重要

異常検知

不正侵入監視

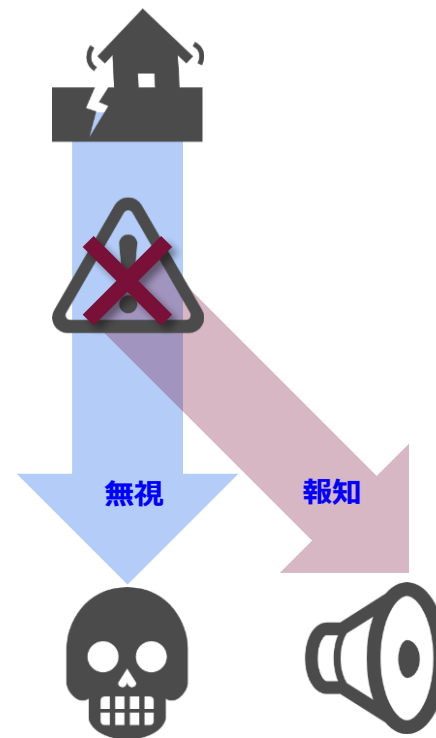
●フェールセキュア・フェールセーフ

フェールセキュア・フェールセーフ

- ・フェールセキュア（フェールセーフ）とは、障害が発生したとき被害を最小限に抑える仕組みです。
- ・自然障害は、システムにどの程普度波及するかわかりません。障害が起きていることを検知する制御機能まで失われてしまう可能性があります。例えば、地震検知システムが狂ってしまった時、何も応答がないとみんな安心してしまいます。
- ・報知機能が止まった時、とりあえず異常事態と報知しておけば人命は助かります。同じように、ファイアウォールなら全て遮断、PCであればブルースクリーン、信号であれば赤を点灯することになります。

システム設定のデフォルト値

- ・システムのデフォルトの設定は、システム設定において何も設定していない場合に採用される設定です。
- ・システム設定パラメータ漏れによってデフォルト値が採用されたまま、システムが運用されたりする場合は脆弱性になりかねないため、安全な設定を読み込まれるように設計されていることがあります。（実際には、初期設定は正常利用できるようにし、細かいセキュリティ設定を管理者に任せる場合の方が多いです。）



報知や制御機構が故障した場合、被害を最小化する状況にする

異常検知

統合監視

● SIEM

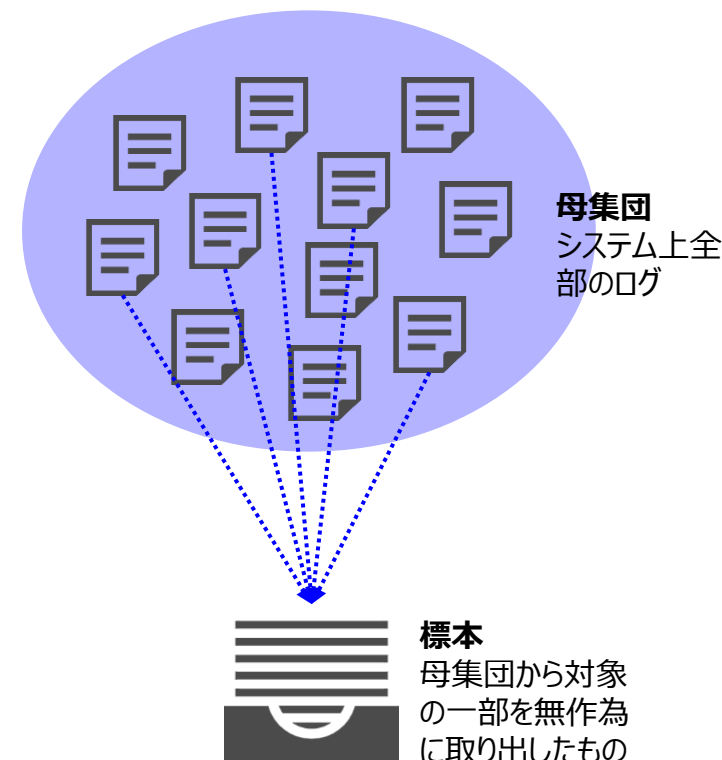
SIEM (Security Information and Event Management) は、ファイアウォールやIDS/IPS、プロキシなどから出力されるログやデータを一元的に集約し、システムの全体像を把握することで、サイバー攻撃やマルウェア感染などのインシデントを検知する仕組みです。

データの相関分析

- UEBA (User and Entity Behavior Analytics、ユーザーとエンティティのふるまい分析) とは、蓄積されたデータをもとにユーザーの行動を特定し、システム上のトラフィックパターンが正当なユーザーのものか、攻撃者のものかを判断する分析です。
- 現代では、SIEMにおいて統計的分析や機械学習を用いた分析機能と認識しておいてよいでしょう。

サンプリング (データ抽出)

- サンプリングとは、調査対象となる母集団の中から直接調査を行うサンプルを抽出することです。
- データを一つずつ確認いき、不正な挙動を行っていることを確認することは不効率な場合があります。ランダムに抽出し調査することで統計的に全体として不正操作がされていない確率を試算します。



サンプリング標本の計測値の特性から
母集団の特性を統計的推測をする

異常検知

統合監視

●SOAR

SOAR (Security Orchestration, Automation and Response) とは、セキュリティインシデントの監視、理解、意思決定、アクションを効率的に行えるようにする技術です。セキュリティ管理者が行っているサイバーインシデントに関する一連の検知から対応までの定型的タスクを自動化します。そして、セキュリティインフラ全体を連動させ生産性を向上させます。一般的に、SIEMと併用され、SIEMで分析・検知された結果に対して適切なセキュリティ対応を示します。

プレイブック (Playbook)

- ドキュメントやチェックリストなどのインシデントを検証する方法をフロー図をベースに定義しています。どのように対応するのも記載されており、必要な経験値を下げることに貢献します。

ランブック (Runbook)

- プレイブックのデータを自動化ツールに適用する事です。これにより、インシデントをプレイブックによって定義し、プレイブックの対応を自動化します。

機械学習

- 定型的な自動化が行われた後は、機械学習が望まれています。
- インシデントからプレイブックに定義する学習領域に関しても、システム化する動きがあります。



プレイブック (Playbook)

(<https://www.rsa.com/content/dam/en/infographic/see-what-rsa-netwitness-orchestrator-can-offer.pdf>)

異常検知

統合監視



● ハニーポットとハニーネット

ハニーポット (Honeypot)

- ハニーポットとは、実際の本番運用システムのように見えるが攻撃者を惹きつけることを目的としたシステムであり、自社の脆弱性や攻撃者が自社のセキュリティ対策が実際にどのように回避するかを知るために使用されます。
- ハニーポットはどのような攻撃をされるのか見るための環境であるために、完全な強化をすることはありません。ハニーポットの結果を持って、実際のデータサーバーは常に完全に強化することが目的です。
- ハニーポットは、攻撃を誘発させることを目的としません。それは非倫理的な行動になります。
- ハニーポットを導入する前に、非常に明確な法的ガイドラインを発行し、シニアマネージャーの承認を得る必要があります。

ハニーネット (Honeynet)

- ハニーネットは、実際の本番運用システムのように見えるが攻撃者を惹きつけることを目的としたネットワークを指します。
- 目的はハニーポットと同じですが、ハニーネット上のトラフィックを観察できるようになっています。

サンドボックス (Sandboxing)

- サンドボックスとは、挙動の不明なソフトウェアの実行環境として用意された、外部へのアクセスが厳しく制限された隔離領域のことです。
- 悪意のあるソフトウェアは実行した時点でネットワーク経由で感染を広げる可能性があり、ネットワーク隔離された状態で動作確認を行う必要があります。

異常検知

統合監視

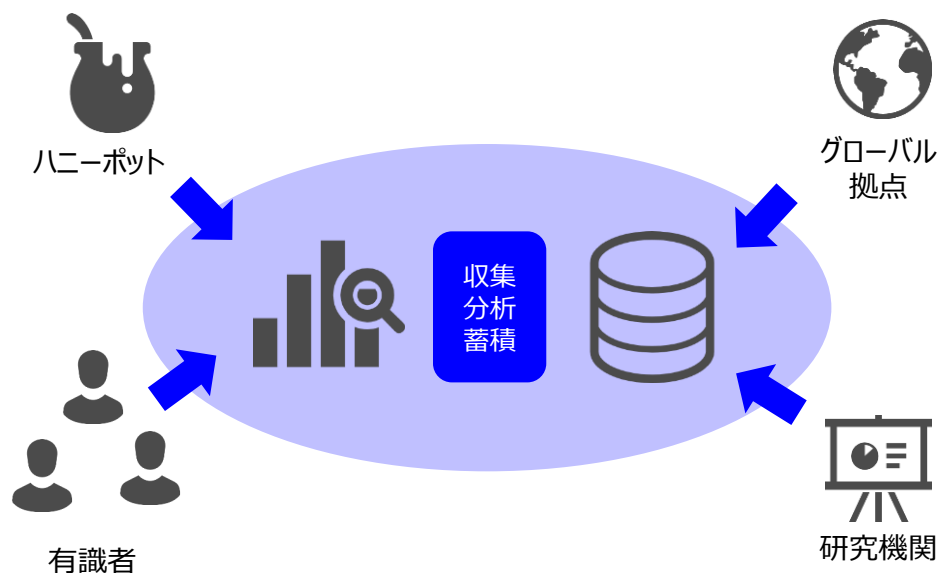
●脅威情報

スレットインテリジェンス（Threat Intelligence）

- スレットインテリジェンス（Threat Intelligence）とは脅威能力の分析を指し、主に脅威情報のデータベースによって達成されます。
- 世界中のネットワークに監視網を張り巡らせ、IPアドレスベースで行動を監視し、悪意度を算出します。この悪意度は、脅威のブロックやフィルタリングに活用できる脅威情報として提供します。
- 脅威の変化に応じて随時更新されていくため、算出と利用のタイムラグにより有効でなくなるということは抑止されています。

セキュリティ侵害インジケータ

- セキュリティ侵害インジケータ（ Indicators of Compromise ）とは、サイバー攻撃を受けていることを示す痕跡です。
- 攻撃を受けたことをなるべく早く察知し、遮断し、影響範囲を限定することが必要になります。なるべく多くの情報源を確保するため、セキュリティ侵害インジケータを他の組織と共有することで、攻撃を早期に発見する活動へにつなげていきます。
- 他の組織と情報を連携の標準がOpenIOCです。OpenIOCはIOC FinderとIOC Editorという早期に攻撃を発見できるような管理者用ツールを提供しています。



あらゆる情報からスレットインテリジェンスとして調査する





運用管理

関連用語

- 要求管理
- 変更管理
- 構成管理
- パッチ管理
- リリース管理
- IDEALモデル
- ログハンドリング
- ATO (Authorization To Operate)
- 運用のセキュリティモード
- ゼロデイ攻撃
- 特権昇格
- バックドア
- ボットネット

運用管理

システム運用

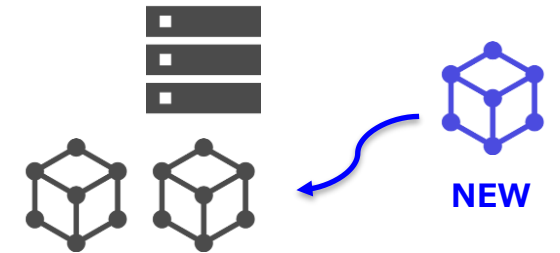
● システム管理

システム運用の目的

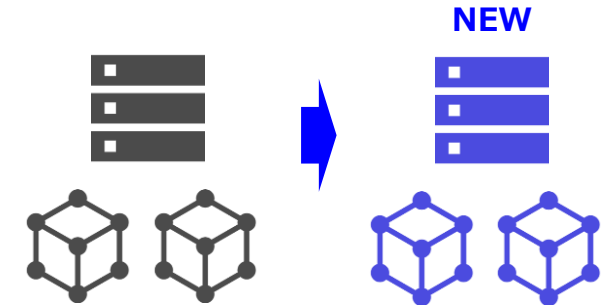
- システム運用は、リリースされた後のサービスを安定稼働し、効率的なサービス提供するために行われます。
- 24時間稼働させるのか、日中帯だけ稼働させるかなど運用方針はサービスごとに異なるため、サービスに合わせた運用の最適化が行われます。
- 運用のルールを変更するタイミングは大きく2つあります。1つ目は、既存の基盤に新しいシステムやサービスを導入した時です。2つ目は、既存の基盤を新しい基盤に更改する時です。

アプリケーション開発と運用チーム

- アプリケーションを開発するチームとそのアプリケーションを利用したサービスを運用するチームは異なります。
- アプリケーション開発を行う際には運用しやすい設計、開発環境から運用環境への迅速なパイプラインの確保を行います。



既存基盤に新しい機能・アプリケーションを導入する



新規基盤に既存機能・アプリケーションを移行する

運用管理

システム運用

● システム管理

運用テスト・引継ぎ

- 運用テストでは、アプリケーションの運用が可能であるかどうかを確認します。メンテナンス画面に切り替えるか、障害検知が行われるか、障害が起きた後のサービスの復旧手順などの運用フローを担保する運用手順書を確認します。

運用テストの成果物

- 運用フローとは、システムや利用者からの問い合わせに対して、だれに連絡を取って、どの手順を見るべきなのかを網羅したフロー図です。
- 運用手順書とは、主にシステム設定の何を修正すべきなのかを把握するためのステップバイステップの資料です。誰が行っても同じ結果になる明瞭さが求められます。手順を簡略化するために、一部の手順を自動化するツールの開発も行われます。



運用フロー

事象に対して従うべき連絡先と運用手順書を記載



運用手順書

システムログの見方や設定変更の手順をステップバイステップで記載



要件定義

基本設計

詳細設計

開発

単体テスト

結合テスト

システムテスト

運用テスト・引継ぎ

リリース

運用

運用管理

システム運用

● 監視管理

- システムの一部に支障をきたしているとき、障害が発生している可能性があります。
- システムのログ、サービス起動状態や疎通状態から監視アラートを上げ、運用管理者に連絡する必要があります。
- 監視アラートを上げる条件はシステムごとに異なります。例えば、一部のサービスが止まった場合には緊急に通知すべき事にも思えますが、冗長化されていれば、全体としてのダウンタイムにはつながりません。また、度々ダウンするようなサービスに関しては、いちいち検知することをやめてしまうこともあるでしょう。緊急に対応が必要なのか、警戒が必要なのかは、そのサービスの停止の影響度から判断されます。



監視名	監視内容
死活監視	PING通信により機器やOSへの疎通を確認する。
ハードウェア監視	SNMPによりハードウェアの異常などを確認する。
リソース監視	CPU、メモリ、ディスクの使用率が閾値を超えていないかを確認する。
プロセス監視	OS上で動作しているプロセスやサービスが起動し続けているかを確認する。
ログ監視	OSやミドルウェアやアプリケーションのログの中身からログレベルが高く緊急性のあるものを確認する。
HTTP監視	HTTPリクエストを送付することによりアプリケーションレイヤーへの疎通を確認する。

運用管理

システム運用

●ログ管理

ログ管理の目的

- ・ 障害調査では、障害発生した場合に、原因を特定するため調査です。
- ・ 監査対応では、情報漏洩や不正アクセスがあった場合に、その操作証跡としてのログを保管しておくための対応です。

ログローテーション

- ・ システム運用期間中はシステムは動き続けているため、ログは出力され続けます。
- ・ ログローテーションは、ログを一定期間でクリアにし、元のログは別名にします。大抵、別名保管されたログは他のサーバーに移動させ、元のサーバーから削除します。

ログ管理の注意点

- ① ログを集めてレビューしない。
- ② ログが十分な時間保管されていない。
- ③ ログのフォーマット等が標準化されていない。
- ④ ログ監視のアラートなどに優先順位がない。
- ⑤ システムエラーログなどの悪いログだけ見る。



1日目



access.log

2日目



access.log



access_01.log

3日目



access.log



access_02.log

削除



access_01.log

1日でログローテートされ3日目以降で削除

運用管理

システム運用

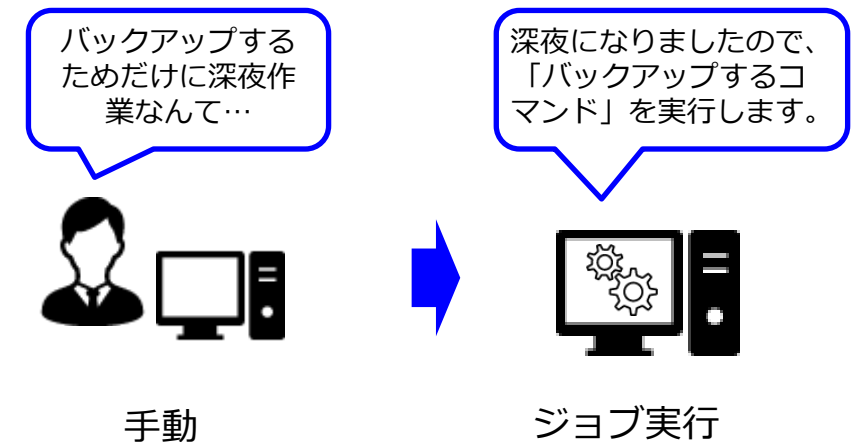


● バックアップ/リストア管理

- データベースやアプリケーションファイルのバックアップは定期的にとることが望まれます。
- ジョブ管理されたコマンドでバックアップ管理が行われ、例えば 1 週間に 1 回など定期的に自動的に実行されます。
- 急なシステムへのアップデートがある場合には、作業前に作業対象システムへの緊急のバックアップが取られます。

● ジョブ管理

- 深夜帯に各サーバーのログのファイルを保存用のストレージに移動させるなど、システム運用上定期的に行う業務があります。このような定期運用業務はシステム内で自動化されることが望ましいでしょう。
- ジョブとは、人間の代わりに実行されるシステムへの業務作業の命令です。ジョブ管理システムによって、各ジョブを定義し実行時間を割り当てます。
- 具体的な作業ではなく、運用業務を行うにあたっての定型作業の自動化管理になります。



運用管理

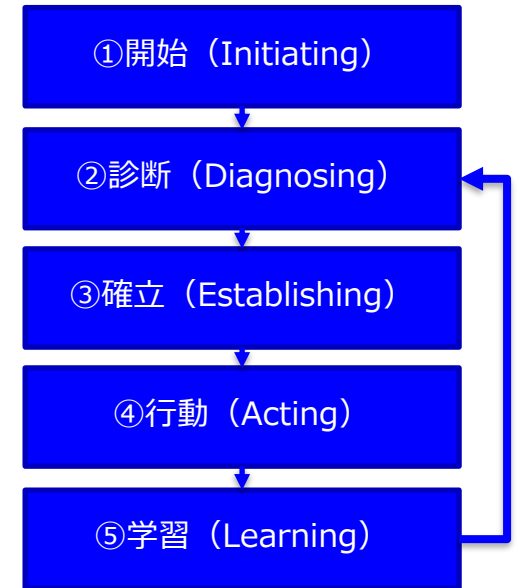
システム運用

● 運用改善

IDEALモデル

IDEALモデルとは、プロセス改善のモデルの一つです。目標の達成や現状の回復のため、改善は常に必要です。改善を正しく行うためにプロセスを理解しておかなければなりません。

- ① 開始 (Initiating) : 目的を明確にして体制を確立する。
- ② 診断 (Diagnosing) : 組織の現状を評価し、目的とのギャップを理解する。
- ③ 確立 (Establishing) : 具体的な改善計画を作成する。
- ④ 行動 (Acting) : プロセス中心アプローチと問題中心アプローチの2つがある。
- ⑤ 学習 (Learning) : これまでを分析して次のサイクルの準備する。



運用管理

変更管理

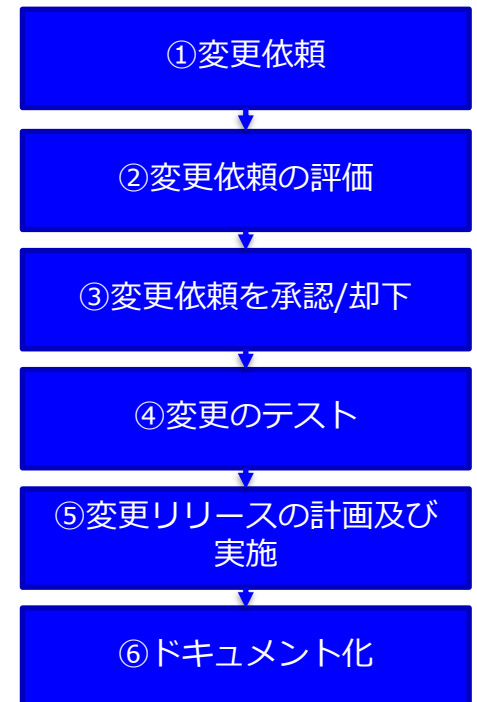


● 変更管理

- ・ 変更管理とは、環境に変更が必要である場合にその変更を適切に行うプロセスです。
- ・ 変更管理は、ハードウェアやソフトウェアに関わらず、すべてのシステムのコンポーネントを対象とします。
- ・ 影響の大きな脆弱性によって緊急対応をしなければなりません。その場合、管理者はドキュメント化を先に実施し、潜在的なリスクを洗い出しておくことが重要です。

変更管理プロセス

- ① 変更依頼：運用管理者や顧客の問い合わせによって、変更依頼がかけられます。
- ② 変更依頼の評価：変更依頼に対してシステム専門家（システム管理者など）がその変更が適切であるかを評価します。
- ③ 変更依頼を承認/却下：システム専門家（システム管理者など）が仮承認か却下かを判定をします。
- ④ 変更のテスト：承認された変更依頼は、実運用サーバーでない開発サーバーでテストされます。期待する結果となることを確認します。
- ⑤ 変更リリースの計画及び実施：影響を受ける関係者への変更通知をします。ピークでない時間帯を調査し、切り戻し計画を準備したうえで実行します。
- ⑥ ドキュメント化：変更箇所に対して文章化します。



運用管理

変更管理

● 変更管理

要求管理

- 要求管理とは、問い合わせやインシデントの要求に対して、対応漏れが出ないように管理することです。
- 要求ごとに優先度の評価も行い、どの要求から対応すべきなのかも決められます。
- 例えば、同じ要件であってもお客様からの問い合わせから発生している場合には、引き続き問い合わせが来ることが予想され、問い合わせ対応負担として弊害が起るため、先んじて対応されるなどの判断がされます。

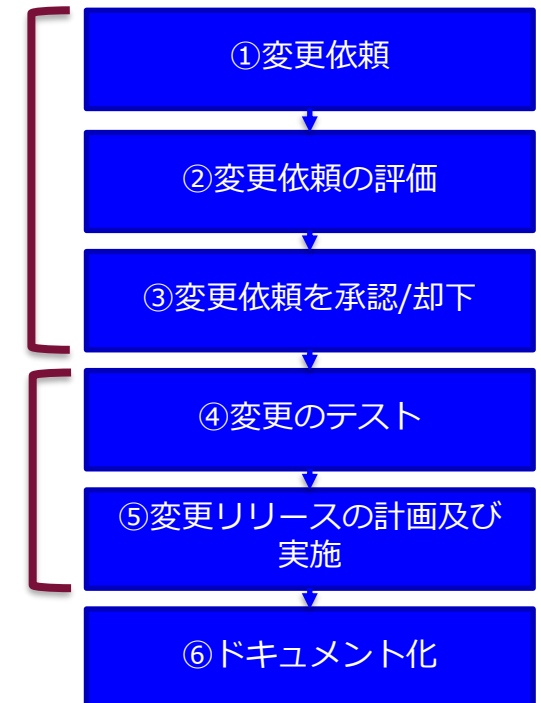
リリース管理

- リリース管理とは、製品リリースの際にテストを含め適切に行われ、影響を少なくリリースすることを管理することです。
- 要望に対するリリース期限、リリース順序、時間帯、関係者への報知などが含まれます。
- リリースはパッチの適用や新機能の搭載、既存バグへの修正などがあり、またサービスの停止を行うかどうかの判断も内容によって異なります。どのリリースから行うべきなのかも含めて管理しておく必要があります。



要求管理

リリース管理



運用管理

変更管理

● 変更管理

脆弱性管理

- 脆弱性管理とは、システムの脆弱性を特定し、評価・解消することです。
- 自システムの各コンポーネントに対して、最新の脆弱性情報を確認し、脆弱性が存在しているかを確認します。
- 脆弱性が発見されれば、ベンダーから公開されている修正パッチをパッチ管理に従って適用します。

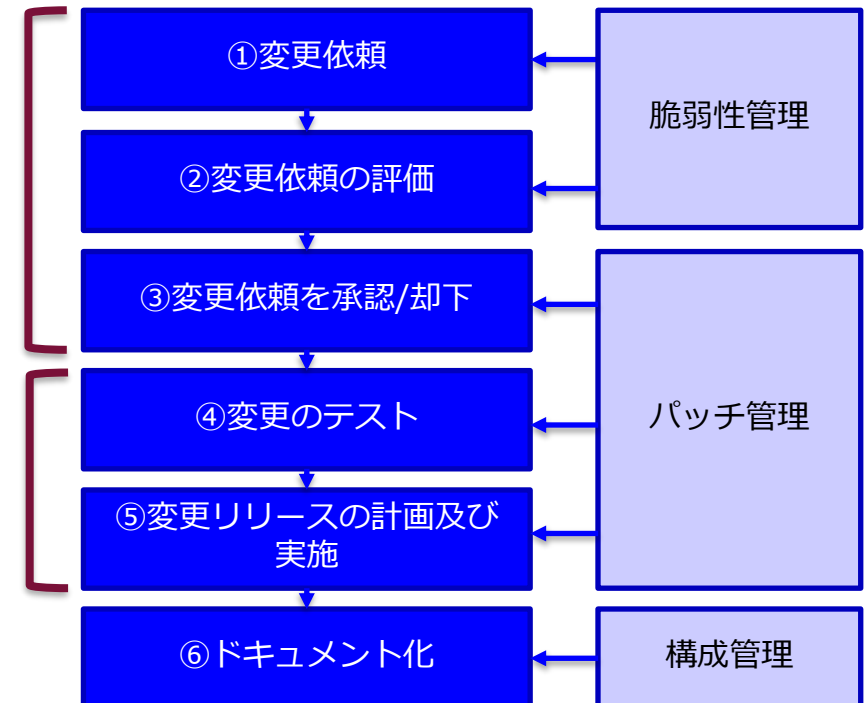
構成管理

- 構成管理とは、システム上で何処に何の製品がどのバージョンであるのかを管理することです。
- システムはいくつもの製品からなります。何がどこにあるのか、いつのバージョンのものなのかを把握しておかないとそのバージョンがサポート切れを起こす場合であっても管理者が気づけない可能性があります。



要求管理

リリース管理



運用管理

変更管理

● 変更管理

パッチ管理

- パッチとはバグや脆弱性もしくは機能改善によって修正されるプログラムであり、パッチ管理ではパッチをいつ適用どのモジュールに適用するのかを管理します。
- パッチはソフトウェア開発側から公開されます。

パッチ管理のプロセス

- ① パッチの評価：パッチの内容を確認し、どのような機能変更が行われるのかを確認します。
- ② パッチのテスト：実運用サーバ以外のサーバにてパッチを適用した場合の影響について実検証します。
- ③ パッチの承認：適用しても問題がないことが確認できたところで承認を取得します。
- ④ パッチの適用（デプロイ）：パッチを実運用環境に適用します。SCCM（System Center Configuration Manager）等の構成管理ツールによって、多数のコンピュータをネットワークを通じてパッチを適用することも可能です。
- ⑤ 適用されたパッチの検証：最後にパッチが適用されたかどうかを確認します。



Patch Tuesday

Microsoft、Adobe、Oracleの製品のセキュリティ更新プログラムの公開時期は決まっています。毎月第2火曜日（米国時間）にリリースされ、“Patch Tuesday”と呼ばれています。

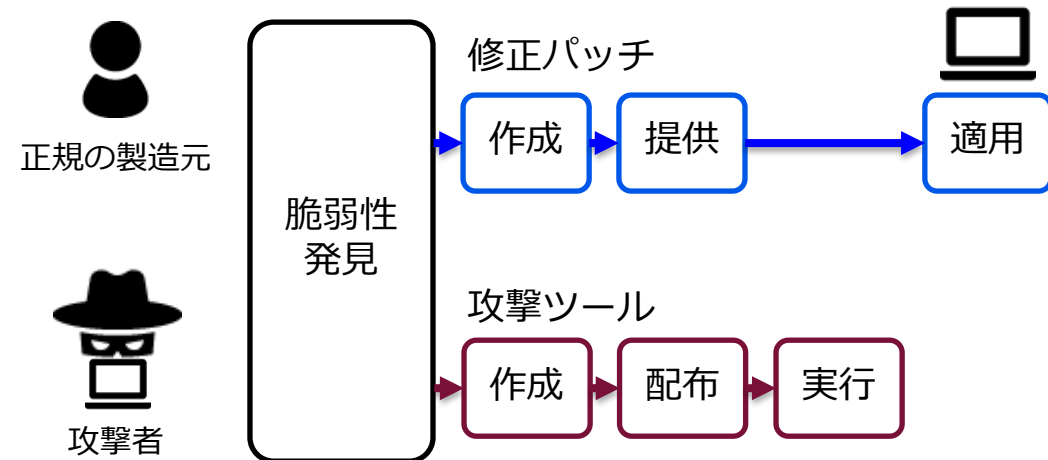
運用管理

運用脆弱性

●ゼロデイ攻撃

ゼロデイ攻撃

- ゼロデイ攻撃とは、一般的に知られていないあるいは発見されていない脆弱性を狙う攻撃のことであり、初めて攻撃が確認された日を「0日」といい、その名前の由来となっています。
- 脆弱性が発見されてから、主要なソフトウェアにパッチやシグネチャがリリースされるまでの期間は短いですが、その間は脆弱性が公開されているが対応していないシステムがあるため、攻撃を行います。
- ゼロデイ攻撃に対する防御は、迅速にセキュリティパッチを適用することです。



脆弱性が発見されたことは正式の製造元だけに伝わるわけではない。

運用管理

運用脆弱性

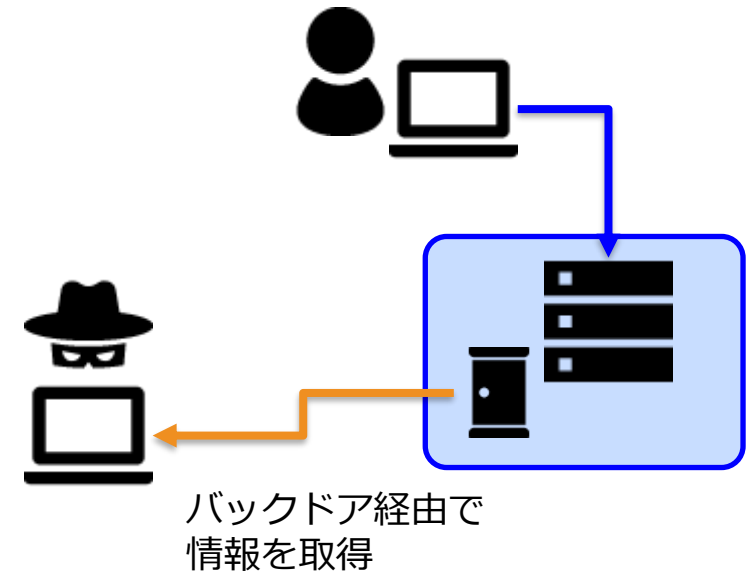
●不正操作

特権昇格 (privilege escalation)

- OSやアプリケーションのバグ、設計上の欠陥、設定の不備などを利用して、通常はアプリケーションやユーザーから保護されているリソースにアクセスすることです。
- 攻撃者の目的は、アクセス権を得たユーザーアカウントを昇格させ、管理者権限を取得することです。
- アプリケーションの開発者やシステム管理者が意図した以上の権限を持ったアプリケーションが不正な動作を行うことになります。

バックドア (backdoor)

- 最初の攻撃が終わった後にシステムへのアクセスを可能にしたり、時間をかけてデータを流出させたり、他のシステムを侵害するために設置されます。
- コンピュータシステム、製品、または組み込みデバイスにおける通常の認証をバイパスとします。
- コンピュータへのリモートアクセスを確保することで、攻撃タイミングをずらし、潜在的な脆弱性になる可能性が高くなります。

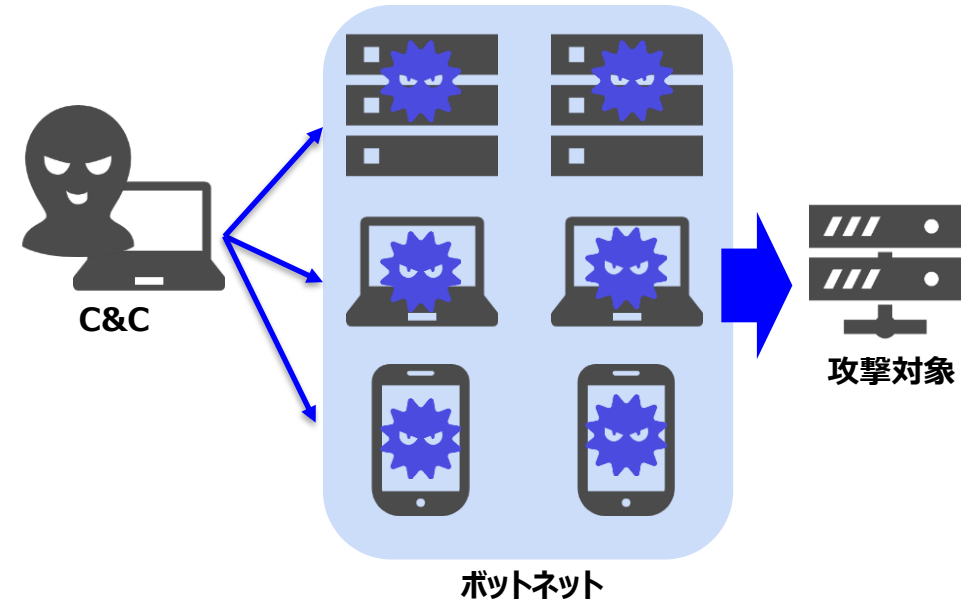


運用管理

運用脆弱性

● ボットネット ボットネット

- ボットとは、ネットワーク経由で遠隔からコマンドを実行できる悪意のあるプログラムです。
- ボットが行う感染しているコンピュータは一般の我々のスマートフォンやパソコンです。当の本人であっても、ボットに感染していることはほとんど気づけません。
- 自身の知らないうちに外部からの命令を受け、DDoS攻撃などのサイバー攻撃の踏み台とされてしまい、あなたの端末が攻撃に加担する可能性があります。
- ボットネットとは、ボットを束ねたネットワークであり、攻撃者はC&Cサーバー（Command and Control server）でボットに対し命令を出して攻撃を行います。



攻撃者はボットネット利用することで
正規の端末から大量の攻撃を仕掛けることができる



耐障害性

関連用語

- フォールトトレランス
- SPOF (Single Point Of Failure)
- 再起動
- バックアップ
- アーカイブビット
- ソフトウェアエスクロウ
- 電子データ保管庫
- VSAN
- RAID
- クラウド
- サービス品質保証 (SLA)
- 相互扶助協定
- HAクラスター
- 無停電電源装置 (UPS)
- 検知器 (熱・火・煙)

耐障害性

フォールトトレランス

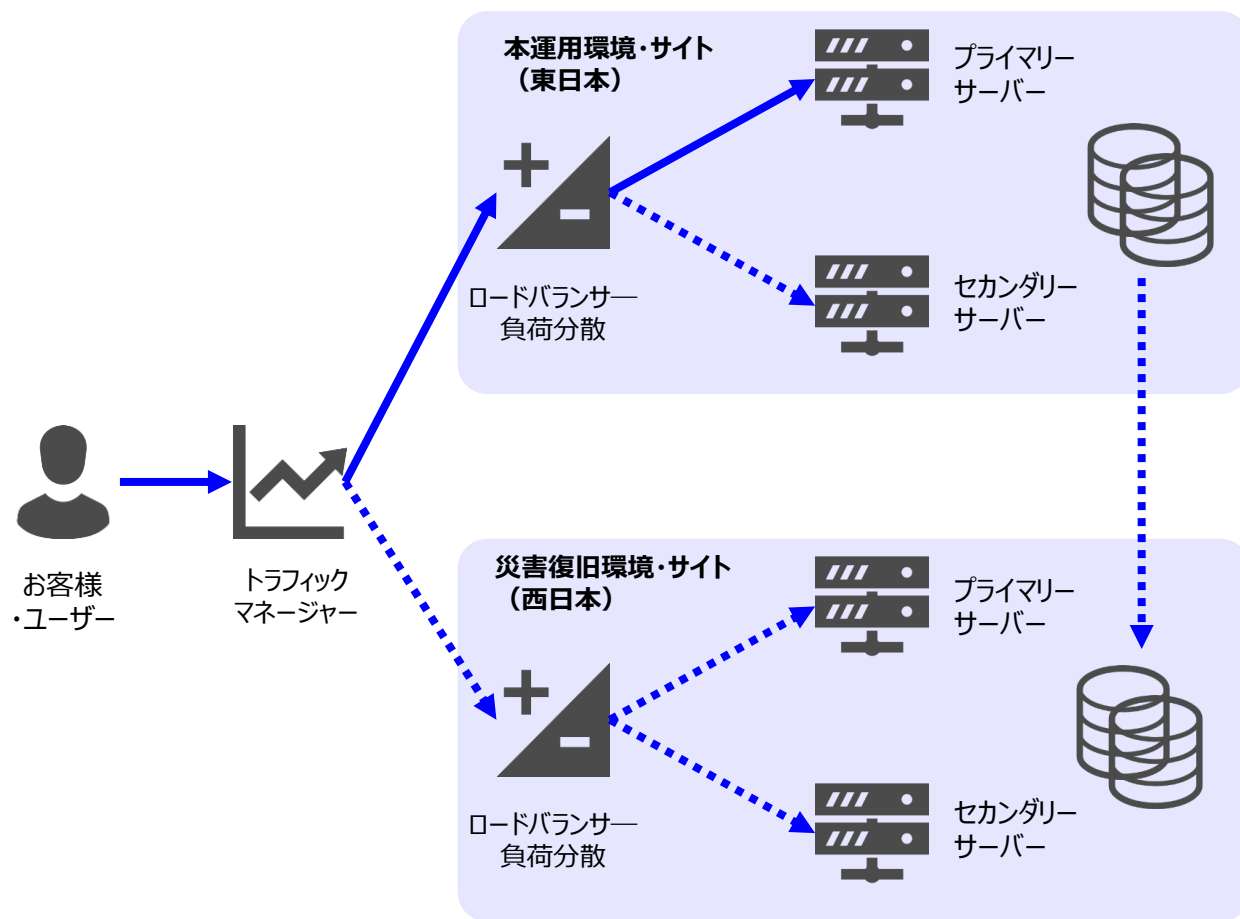
●フォールトトレランス

SPOF (Single Point Of Failure)

- SPOF (Single Point Of Failure) とは、一つの障害ポイントにより、システム全体が停止される構成を指します。
- 1つのサーバや1つのDBや1つのアプリケーションに障害が発生しただけでダウンすることは望まれません。
- 障害が発生した際に、システムとして耐えうる（フォールトトレランス）対策を講じる必要があります。

フェールオーバー・フェールバック

- フェールオーバーとは、プライマリコンピューターからセカンダリーコンピューターにトラフィックの主を変えることです。つまり予備への切り替えです。
- フェールバックとは、セカンダリーコンピューターからプライマリコンピューターにトラフィックの主を変えることです。つまり本運用への切り戻しです。



データセンターサイトは地理的に分離、それぞれプライマリ・セカンダリーサーバに分離

耐障害性

フォールトトレランス

● クラスター化

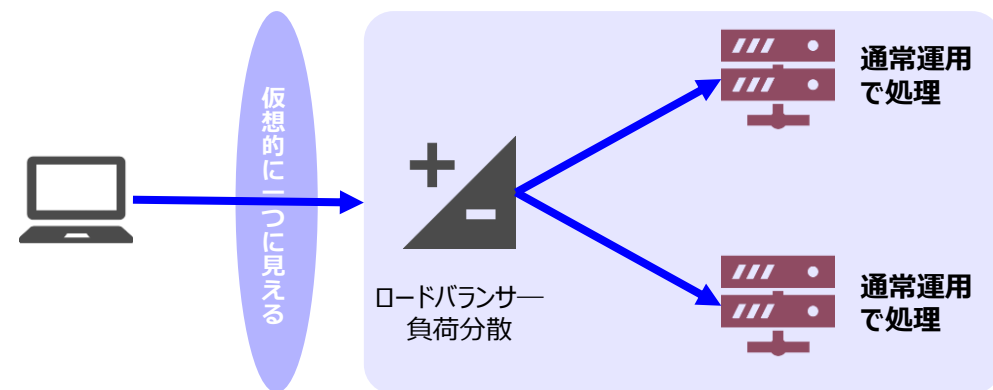
重要なアプリケーションやシステムは、クラスター化することもあります。クラスター化すると、複数の同じコンピュータが仮想IPで接続され、クライアントからは1つのコンピュータとして見えます。

アクティブ/アクティブ構成

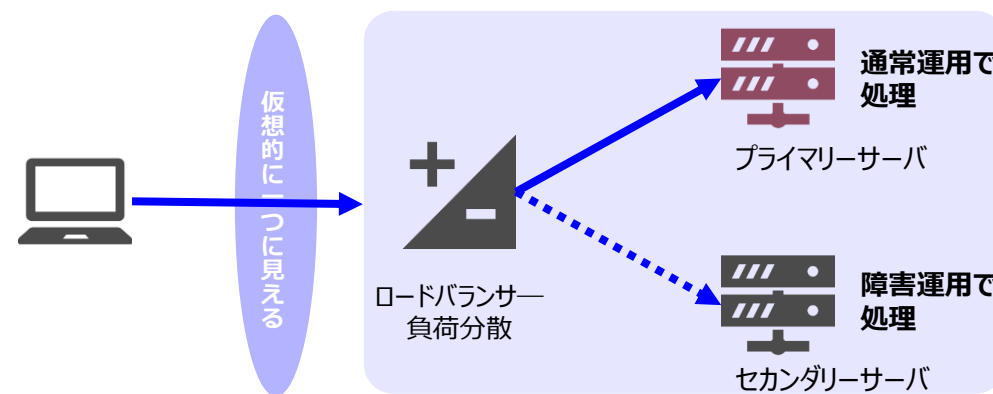
- アクティブ/アクティブ構成とは、クラスターを構成するサーバはどちらもトラフィックを受け入れる状態であり、負荷分散でトラフィックが分散されます。
- 両系の性能を確保することができます。ただし、消耗が両系にかかるため両系ダウンの可能性もあります。

アクティブ/パッシブ構成

- プライマリアクティブサーバーとセカンダリパッシブサーバーがあります。セカンダリパッシブサーバーはキープアライブまたはハートビートをプライマリアクティブサーバー送信し、プライマリアクティブサーバーが応答する限り、プライマリアクティブサーバーに処理を行ってもらいます。



Active/Active構成



Active/Standby構成

耐障害性

フォールトトレランス

● バックアップ

バックアップポリシー

- バックアップを保管する理由は、フォールトトレランスつまり耐障害性を確保するためです。
- バックアップには、フルバックアップ、増分バックアップ、差分バックアップ、コピーバックアップがあります。どれだけのデータを失うことに耐えられるか、バックアップと復元のプロセスをどれだけ速くしたいかによって決まります。
- バックアップは営業時間外に行うことが望ましいです。
- OS、ゴミ箱、特定のプログラムフォルダなど、バックアップするシステムの一部を除外したいことがよくあります。重要なものをバックアップし、すべてをバックアップしないことはおかしいことはありません。

完全（フル）バックアップ

- フルバックアップとは、データベース全体またはシステムのすべてをバックアップします。大規模なデータセットになるため、フルバックアップに何時間もかかることもあります。
- フルバックアップでは、すべてのアーカイブビットが消去されます。

アーカイブビット

- アーカイブビットとは、前回のフルバックアップまたは増分バックアップ以降にファイルが変更されたかどうかを示すフラグです。
- WindowsのNTFSではファイルにアーカイブビットが設定されています。



コピーバックアップ

コピーバックアップとは、フルバックアップになりますが、アーカイブビットがクリアされない違いがあります。システムのアップデートやパッチなどのアップグレード前などの、バックアップサイクルを乱したくないが何かあったときに以前の良い状態に戻せるようにしておきたい目的で使われます。

耐障害性

フォールトトレランス

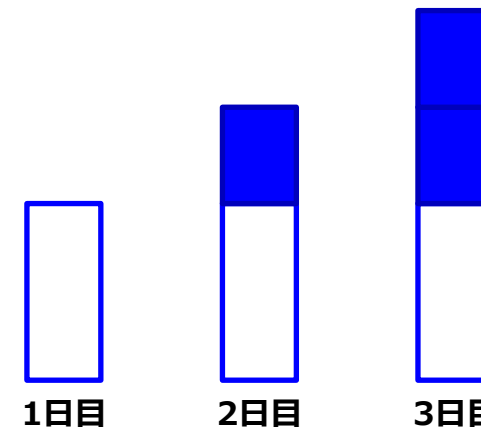
●バックアップ

差分バックアップ（ Differential backup ）

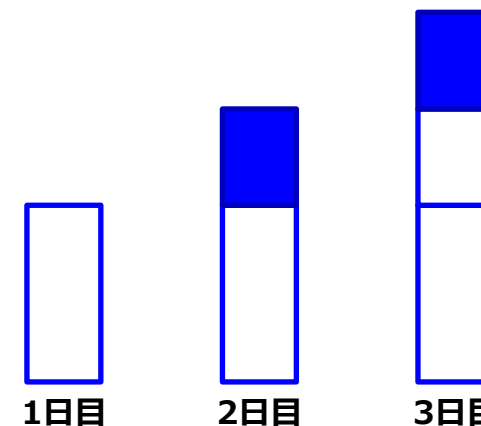
- 差分バックアップとは、最後のフルバックアップ以降のすべてのデータをバックアップします。その際に、アーカイブビットは消去されません。
- フルリストアに必要なテープは、フルと差分の2本だけなので、リストアが早くなります。

増分バックアップ（ Incremental backup ）

- 増分バックアップとは、最後のバックアップから変更されたデータをバックアップします。その際に、アーカイブビットを消去します。
- 不利な点は、増分のバックアップ数が多い場合、フルリストアを行う際にバックアップ数とリストア時間を要することです。



前回フルバックアップからの差分をバックアップ



前回バックアップからの増分をバックアップ

耐障害性

フォールトトレランス

●データベースの冗長性

電子データ保管庫（e-vaulting）

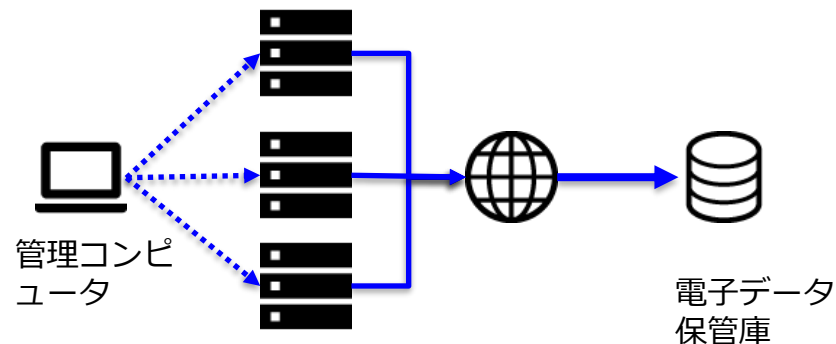
- 電子データ保管庫とは、リモートバックアップサービスを利用して、一定の間隔またはファイルが変更されたときに、バックアップをオフサイトに電子的に送信することです。
- 災害時の施設の破壊を想定し、地理的に別の場所に、別のメディアでコピーすることが推奨されています。

データベースシャドウイング（レプリケーション）

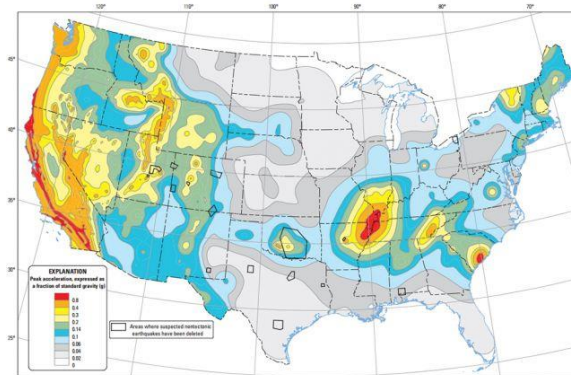
- データベースシャドウイングとは、データベースやファイルを別の場所に正確にリアルタイムでデータファイルをコピーすることです。
- 主系のデータベースダウンの際に、コピー先にデータベースに切り替えることで復旧できます。

リモートジャーナリング

- リモートジャーナリングとは、ファイルそのものではなくトランザクション・ログ・ファイルを送信することです。
- 処理中に障害が起きると、実行中のデータが更新後なのか更新前なのかを判断するのに役立ちます。



リモートに存在する電子データ保管庫にローカルデータを保管する



合衆国の地震ハザードマップ

(<https://www.americangeosciences.org/critical-issues/maps/national-seismic-hazard-map>)

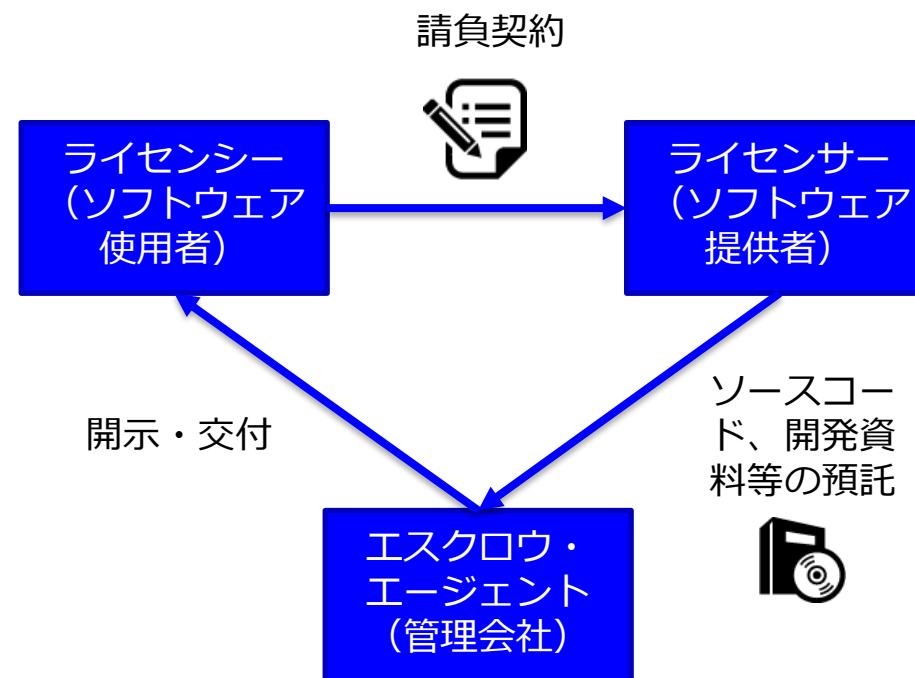
耐障害性

フォールトトレランス

●ソフトウェアのバックアップ

ソフトウェア・エスクロウ

- ソフトウェア・エスクロウとは、ソフトウェアのライセンスを販売している以外の組織に預けることです。
- 企業向けソフトウェアには、利用する権利であるライセンスの購入が必須です。しかし、企業が倒産してしまうとライセンスを提供することができなくなります。こうなると、次に困るのがライセンスを購入して、使っている企業です。そのため、ライセンスを第3組織（エスクローエージェント）に預け、運用を続ける方法があります。



耐障害性

インフラ設備の冗長化

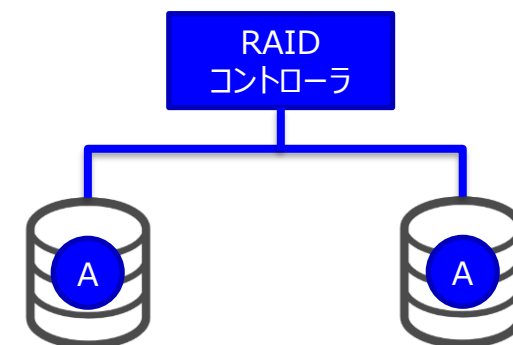
● ディスクの冗長化

ディスクミラーリング

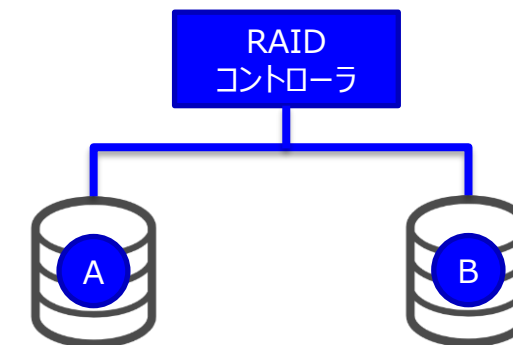
- ディスクミラーリングとは、RAIDコントローラが同じデータを複数のハードディスクに書き込むことです。
- 同じデータを保存するのに最低でも2倍の数のディスクを使用するため、最低でも2台のディスクが必要となります。

ディスクストライピング

- ディスクストライピングとは、RAIDコントローラが複数のディスクに同時にデータを分離して書き込むことです。元のデータに戻す際には、再度組み合わせが必要になります。
- 冗長性を確保するためにストライピングと同時に他のディスクのデータが変わっていないかを確認するパリティを使用します。パリティを使用して冗長性を確保する場合は、少なくとも3台のディスクが必要です。



ディスクミラーリングで複数のディスク
に同じデータを書き込む



ディスクストライピングで分割して別
のディスクに書き込む



耐障害性

インフラ設備の冗長化

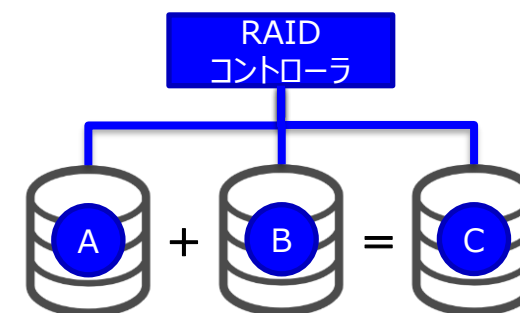
● ディスクの冗長化

パリティ

- パリティとは、複数のデータから算出できる演算結果です。例えば、 $A + B = C$ ということを計算して置けば、たとえBが消えたとしても $C - A$ で算出できます。Cがパリティを指し、Bが破損したディスクのデータを指します。
- デジタルの世界は2進法ですから、演算にも排他的論理和が使われます。排他的論理和メンドイ方向けに2進数を奇数・偶数で示しますが、“Aは奇数 + Bは偶数 = Cは奇数”であれば、たとえBが消えたとしても算出できるでしょう。
- ただし、AもBも破損してしまうと、どちらのディスクに何のデータが入っていたかが分からなくなってしまい復旧できません。

排他的論理和

A	B	XOR
0	0	0
0	1	1
1	0	1
1	1	0



耐障害性

インフラ設備の冗長化



● RAID (Redundant Array of Independent/Inexpensive Disks)

RAID (Redundant Array of Independent/Inexpensive Disks) とは、複数台のハードディスクを1台のハードディスクとして運用するための技術です。記録するデータをどのようにハードディスクに書き込むのかによって物理的な冗長性を向上させる仕組みを持っています。

RAID 0

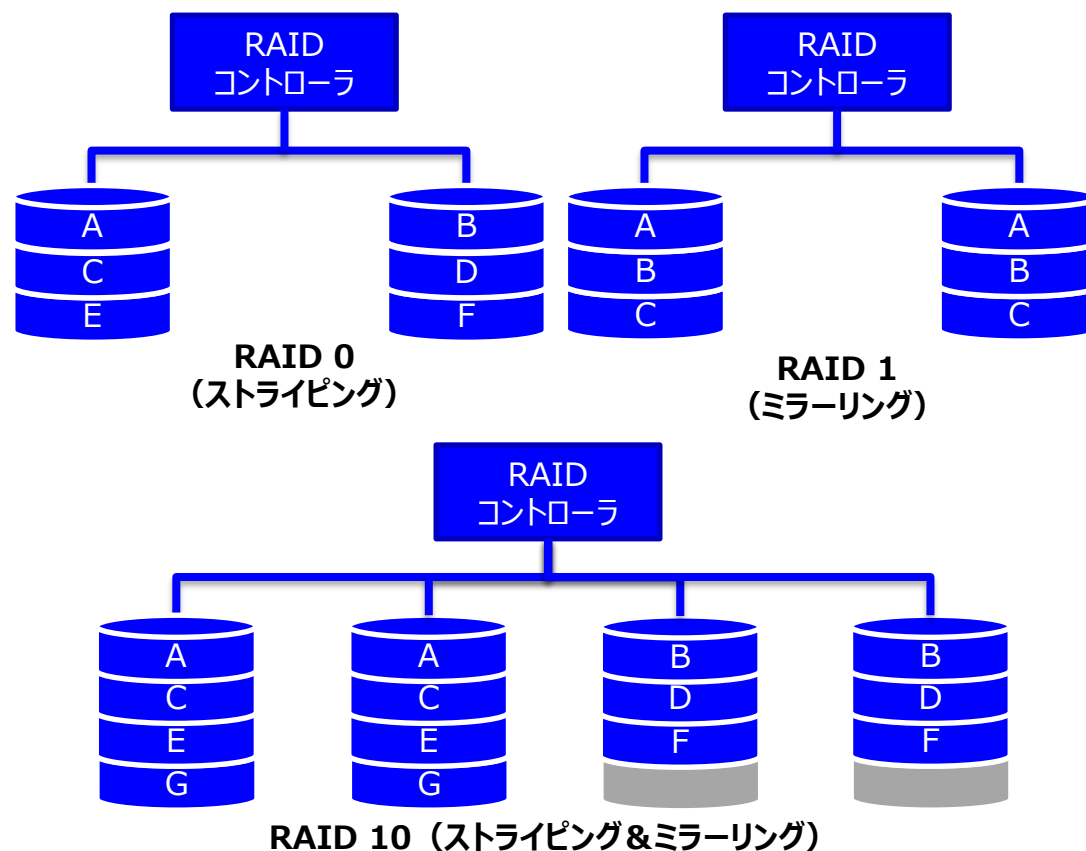
- ミラーリングやパリティのないストライピングで、フォールトトレランスはなく、リード・ライトの速度のみが速く、最低2台のディスクが必要です。

RAID 1

- 複数ディスクに同一のデータを保管する構成であり、書き込み機能は両方のディスクに同時に書き込まれます。

RAID 10

- RAID 0とRAID 1を組み合わせたRAID方式がRAID 10です。
- RAID 0のように別のディスクに同時に書き込みますが、RAID 1のように別のディスクは複数台で冗長化されています。



耐障害性

インフラ設備の冗長化



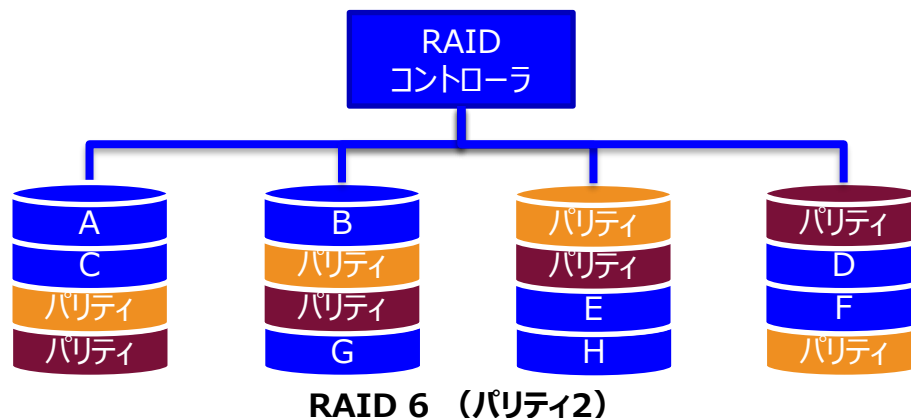
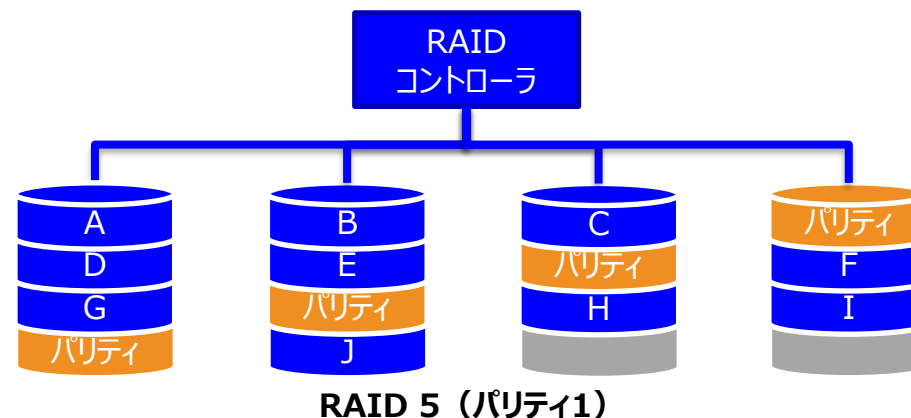
● RAID (Redundant Array of Independent/Inexpensive Disks)

RAID 5

- 分散パリティによるブロックレベルのストライピングで、最低でも3台のディスクが必要です。
- パリティが使われあるディスク1台が落ちたとしても復旧できるようになっていますが、ディスク2台が破損した場合には復旧できなくなります。
- 速度と冗長性を兼ね備えています。

RAID 6

- RAID 5と同様に分散パリティによるブロックレベルのストライピングを利用します。ただし、パリティを二重で生成し、異なるディスクに記録します。
- 生成されるパリティが多いため、書き込みや必要な容量がRAID 5よりもかかりますが、RAID 5より耐障害性が高くなります。



耐障害性

インフラ設備の冗長化

●アーキテクチャ

クラウドシステム

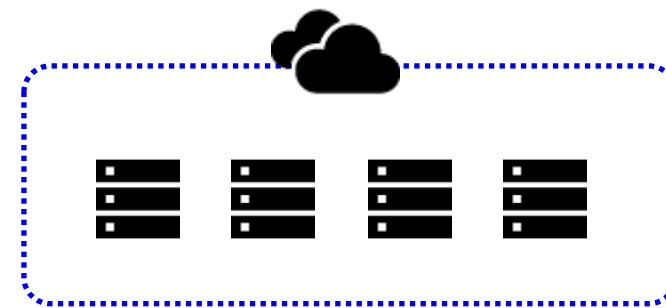
- クラウドシステムは、巨大なデータセンターに配置されたサーバー群によって構成される仮想環境を小分けにして提供するシステムです。
- そのため、物理的なサーバーの管理をする必要はありませんし、その物理的管理の複雑性も回避したサービス提供をしています。
- また、クラウドシステムによって、本番環境の最小または完全なレプリカを一定の時間内に稼働させることが可能です。オンプレ上のアプリケーションはプライマリーシステムで動作させ、クラウド上のレプリカはデータのバックアップを受け取ります。プライマリーシステムが完全にダウンした場合には、クラウドシステムはバックアップを適用してもらい、サービス稼働を続ける構成もあります。

無停電電源装置（UPS、Uninterruptible Power Supply）

- 無停電電源装置（UPS、Uninterruptible Power Supply）とは、電気が途絶えた時に一定時間電力を供給する電源装置です。
- 地震などによって、電気が途絶えてしまうことがあります。そういった時、緊急通報や自動ドアなどもダウンしてしまっては非常にリスクです。完全に電気が途絶えても一定時間は稼働できるようにしておきます。

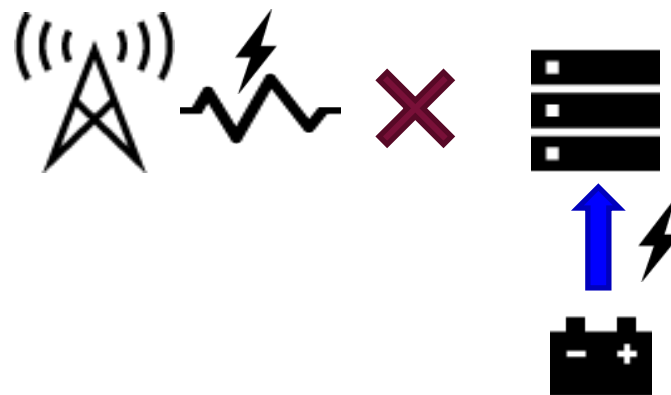


クラウドシステム



クラウドでの冗長化は技術的にオンプレより簡易

無停電電源装置



耐障害性

インフラ設備の冗長化

● 契約

サービス品質保証

- サービス品質保証（SLA、Service Level Agreements）とは、利用量や障害復旧などのサービス品質の合意です。
- クラウドといったインフラ設備やプラットフォームに対して、システム稼働における可用性や性能といった品質項目と水準を定めます。

相互扶助協定

- 相互扶助協定（MAA、Mutual Assistance Agreement、Reciprocal Assistance Agreement）とは、自身組織だけでセカンダリ-の環境を用意することが難しい場合、他の組織との間で災害時にデータセンターの装備を提供する契約です。
- 契約により、相互の利得が均一されていることを求められるために、自身の組織のためにセカンダリ-を強化するといったことが難しい傾向があります。
- 同じスペースを別の組織が利用するために、セキュリティ事項をすり合わせておかないと、共有による漏洩が発生する可能性があります。



サービス品質保証



相互扶助協定





事業継続計画

関連用語

- 人命救助
- バイタルレコード
- 事業継続計画
- 災害復旧計画
- 障害の分類（自然・人為・環境）
- コールツリー
- 事業影響分析
- 稼働率
- RASIS
- 最大許容停止時間
- 最小動作要件
- DRサイト
- サイバーインシデント対応計画（CIR）
- 危機管理計画（CCP）
- 非常オペレーションセンター（EOC）
- チェックリスト（Read-Through）
- ウォークスルー
- ウォークスルードリル
- NIST SP 800-34
- ISC/IEC-27031
- BCI

事業継続計画

事業継続計画の策定

● BCPとDRP

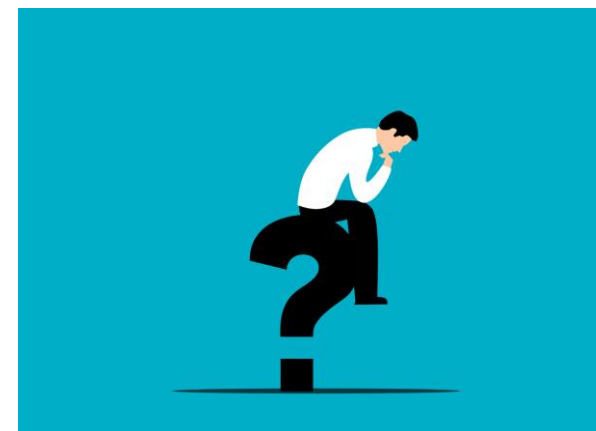
どのような組織でも災害に遭遇することがあるでしょう。どのようにして災害を回避し、どのようにして災害を軽減し、どのようにして災害が発生したときに回復するかが非常に重要です。このプロセスを怠ると、組織に深刻な影響を与えたり、事業を閉鎖しなければならないこともあります。ただし、こういった計画の数値的な根拠は経済的メリットによって決定づけられますが、災害の際に最も守らなければならないのは人命です。



難しいBCPは意味ある？

事業継続計画と聞くと、「どんな異常事態であっても信頼を損ねない論理的な計画」という意味合いに感じられるかもしれませんが、そうではありません。むしろ、そのような考え方が無理な計画を作り上げてしまい、非常に厄介で無意味なものと感じることもあるでしょう。

難しいことは考えず、“とりあえずデータを復旧するには？”という考え方が重要になります。もっと優しくいうと、“私物のスマホが壊れたら、何をすればいいんだっけ？”ぐらいのノリで、詳細を詰めていけばいいのです。



事業継続計画

事業継続計画の策定



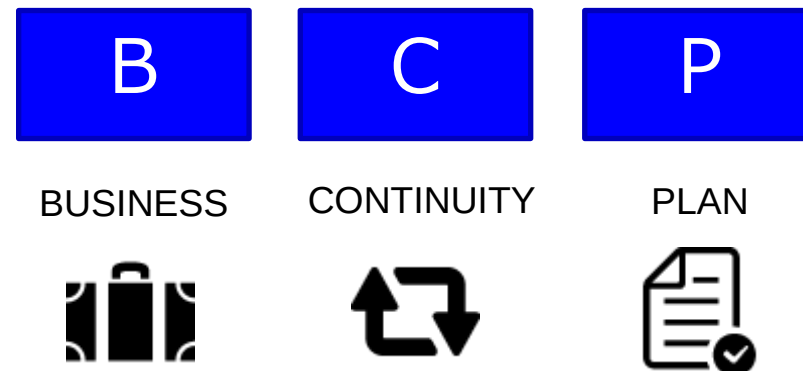
● BCPとDRP

事業継続計画（BCP、Business Continuity Plan）

- 事業継続計画とは、事業を継続するための長期的な戦略的事業計画、方針、手順です。
- ITシステムだけでなく、影響を受ける可能性のある組織全体を対象とします。
- さまざまな災害シナリオと復旧のためにプロセスで組織がとるべき指針を記載しています。
- 事業継続計画は当然破壊的な事象が起こる前に作成され、継続的に改善されていくものです。

災害復旧計画（DRP、Disaster Recovery Plan）

- 災害復旧計画とは、事業継続計画の一つであり、災害時に重要なITシステムの復旧または継続を可能にするための短期的な計画です。
- 事業継続計画は、事業を継続するための全体を対象としているため復旧だけではなく、その健全性の維持も含まれます。つまり、ITシステムの内容を主題としません。
- 重要なビジネス機能を支えるITシステムに焦点を当て、災害後にそれらをどのように復旧させるかを考えます。



いざ！いざ！いざ！

引っ越しの時に物が捨てられないことはよくあります。会社も同じです。代替手段を用意しすぎるというのは、BCPではよくあるミスの一つです。代替手段があるということは、その分維持管理費もかかるということです。

事業継続計画

事業継続計画の策定



● 災害分類

自然

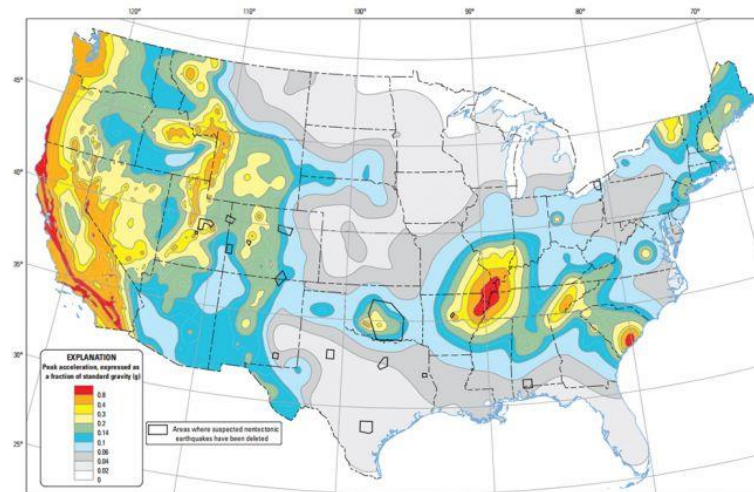
- 地震、洪水、雪、竜巻、パンデミックなど、自然が原因で起こる災害があります。
- 非常に壊滅的な被害をもたらす可能性がありますが、他のタイプの脅威に比べてあまり一般的ではありません。
- 自然災害の脅威は地域によって異なりますが、私たちは地域のリスク分析を行い、場所によっては建物やデータセンターを地震に強くしたり、洪水に対して強くする選択をするでしょう。

人間

- 人間に起因するものは、意図的な災害と非意図的な災害があります。
- 非意図的とは、従業員がマルウェアを拡散させてしまった場合などです。
- 意図的なものとしては、テロリズム、ハクティビズム、フィッシングなどが考えられます。

環境

- 環境に起因するものとしては、停電やスパイク、ハードウェアの故障、プロバイダーの問題などが考えられます。
- 多くの場合軽微な影響しか与えませんが、潜在的なダメージを与える可能性がある問題がある場合は、軽減策を打ち出すべきです。



合衆国の地震ハザードマップ

(<https://www.americangeosciences.org/critical-issues/maps/national-seismic-hazard-map>)

事業継続計画

事業継続計画の策定



● 災害の例

電力（環境）

- 環境の設備が原因によって、電力の停止を招く可能性があります。
- UPSと発電機の冗長性を確保することで、長期間サイトを維持するためのバッテリーや発電機のバックアップを適切に行います。

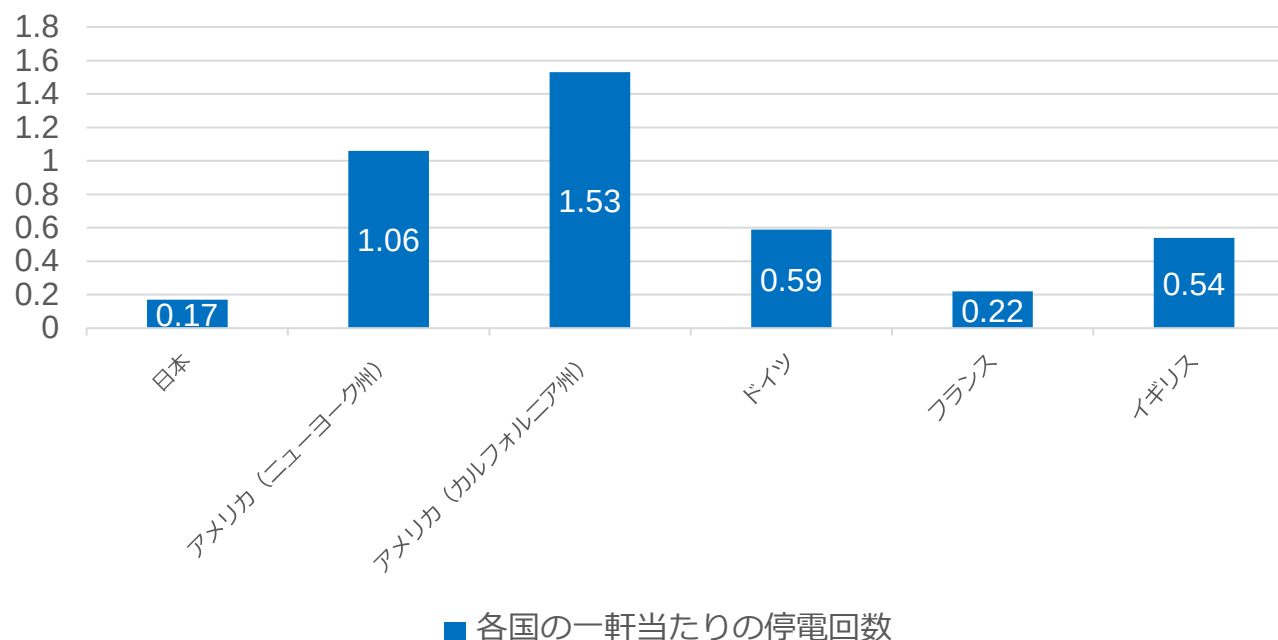
熱、圧力、湿度（環境）

- 湿度が低いと静電気が発生し、湿度が高いと金属（電子機器）が腐食します。

戦争、テロ、サボタージュ（人間）

- インターネットでは、国や宗教などの理由でハッキングを行うことが多くなっています。
- 約120カ国がインターネットを武器として、金融市場、政府のコンピュータシステム、公共施設などを標的にする方法を開発しています。

各国の一軒当たりの停電回数



1. 日本・米国(ニューヨーク)は2020年度の事故停電・作業停電実績。米国(カリフォルニア)は2019年度の事故停電・作業停電実績。(出典) 電力広域的運営推進機関「電気の質に関する報告書（2020年度実績）」

2. ドイツ・フランス・イギリスは2016年の事故停電・作業停電実績。(出典) CEER「Benchmarking Report 6.1 on the Continuity of Electricity and Gas Supply」

事業継続計画

事業継続計画の策定



●災害の例

金銭目的の攻撃者（人間）

- 金銭的な動機を持った攻撃者が増えています、高度な技術を持っている場合とそうでない場合があります。
- 低いスキルのものは、フィッシング攻撃、ソーシャルエンジニアリングなどを考えるでしょう。より高いスキルのものとしては、カード会員データの窃盗、個人情報の盗難、偽のアンチマルウェアツール、企業スパイなどを考えるでしょう。

パンデミック（自然）

- インフルエンザやその他のウイルスなどの自然現象によって人員不足が引き起こされることもあります。
- 人員の冗長性を確保し、人員が不足した場合に対処します。

地震とか言われても、イメージしにくいのですが…

自然災害系の障害については、発生する頻度が少ないため想定することが難しいでしょう。そういった場合には、自分らで考えるのではなく、専門家に頼ってもいいでしょう。日本では、防災訓練・防災教室も消防署に頼めば無料で指導してくれたり、指導を受けたうえで損害があった場合に補償を付ける場合もあります。（※詳細につきましては消防署にてご確認ください。）

事業継続計画

事業継続計画の策定



● 事業継続計画の策定プロセス

① プロジェクトの開始

- ・ ステークホルダーを特定し、Cレベル（CEOなど）の承認を得て正式に決定します。
- ・ 組織のリーダーであるシニアマネージャーは最終的に責任を負い、当然ながら優先順位、実行、計画そのものについて最終的な決定権を持っています。

② プロジェクトの範囲設定

- ・ 何をやろうとしているのかを明確にします。何を行い、何処まで保証するものなのかを明文化します。

③ 事業影響分析（BIA、Business Impact Analysis）

- ・ 重要なシステムやコンポーネントを特定し、優先順位をつけます。
- ・ 優先順位は、業務やシステムが停止した場合に事業に与える影響度から評価します。

④ 予防的コントロールの識別

- ・ 各システムやコンポーネントに対して、現在の予防的コントロールを特定します。
- ・ 予防的コントロールが適用されていない箇所があるのか、適切な予防的なコントロールが行われているのかを把握するために整理します。

① プロジェクトの開始

② プロジェクトの範囲設定

③ 事業影響分析

④ 予防的コントロールの識別

⑤ 復旧戦略

⑥ プランの設計と開発

⑦ 模擬試験

⑧ BCP/DRPのメンテナンス

事業継続計画

事業継続計画の策定



● 事業継続計画の策定プロセス

⑤ 復旧戦略

- DRサイトなどをどのようにして効率的に復旧させるのか戦略を検討します。
- 具体的な手順等については、次のフェーズで決定します。

⑥ 計画設計と開発

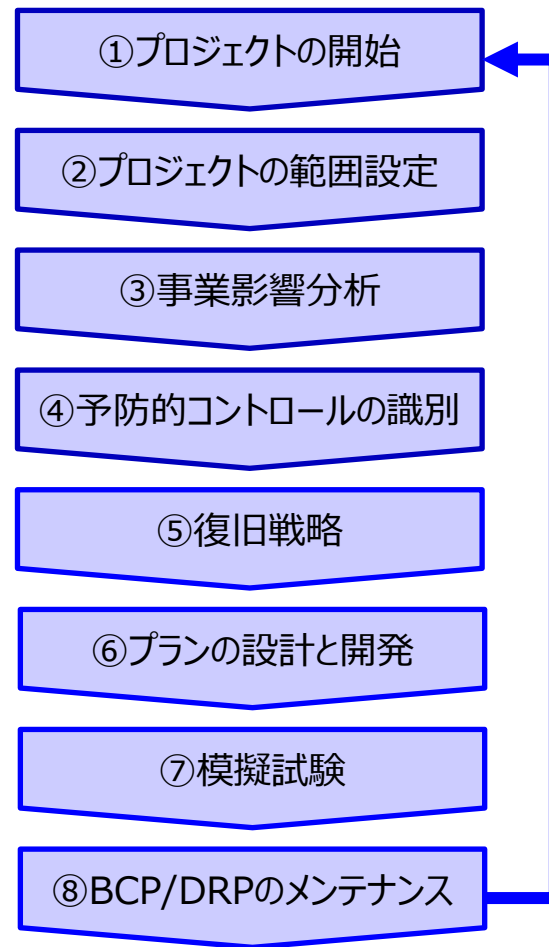
- 復旧のための具体的な計画、手順、ガイドラインなどを策定、復旧のためのツールを開発します。

⑦ 模擬試験

- 計画を実際にテストすることで、現実的に機能するのかを確認します。
- 計画に基づいて行動できるようにスタッフを訓練します。

⑧ BCP/DRPのメンテナンス

- トレーニングで得られた教訓を計画に落とし込みます。
- 脅威の状況が変化の中で、BCPやDRPの改善や調整を続けなければなりません。



事業継続計画

事業継続計画の策定



●BCP/DRPのフレームワーク

NIST 800-34

- NIST 800-34では、連邦政府の情報システムの危機管理計画に関する指示、勧告、考慮事項を提供しています。
- 危機管理計画とは、障害発生後に情報システムのサービスを回復させるための暫定的な手段を指します。

ISO/IEC 27031

- ISO/IEC 27031では、社会的セキュリティ、事業継続マネジメントシステムのガイダンスとして、事業継続マネジメントに関するより実用的なアドバイスを提供しています。
- ISO 22301は、社会的セキュリティ、事業継続マネジメントシステム、組織の事業継続計画を管理するためのマネジメントシステムを規定しており、ISO 27031でサポートされています。

BCI (Business Continuity Institute)

- BCI (Business Continuity Institute) とは、事業継続について活動している人たちが情報を互いに交換・提供するための組織です。
- 事業継続に関する独立した知識体系である「GPG (Good Practice Guidelines)」の6ステッププロセスを提示しています。

それって計画？それとも穴埋め？

事業継続計画にはいくつかのひな型がありますが、企業とはこうあるべきであるという教義的な解釈では、おそらくあなたはBCPに価値を見出せないでしょう。ただ項目を埋めた街頭アンケートのように、事業継続計画というシートの穴埋めをただで、事業を継続する効力など全くないケースもあります。

事業継続計画

ビジネスインパクト分析



●事業影響分析

事業影響分析/ビジネスインパクト分析（BIA、Business Impact Analysis）

- 事業影響分析によって、組織のシステム、機能、活動の重要性と非重要性を特定します。
- 主な目的は、関係者の部門にビジネスプロセスのリスクを認識させ、確認することです。より具体的に言うと、既存のあらゆる制御が機能しなくなった場合の最悪のケースを理解することです。
- 主な活動として、クリティカルな箇所を特定します。クリティカルとは、破壊が許容できないと考えられる場合で、許容できるかどうかは回復コストにもよります。個人情報などの情報の保護が法律で定められている場合もその対象となります。これに加えて、経済的、政治的、社会的、環境的なリスクはないかを考慮します。
- 事業影響分析は、DRP/BCPを策定する前の事前調査のプロセスに位置します。
- 承認は経営者レベル以上で行われます。

調査

承認

対策

事業影響分析

上級管理者に
連携・説明

DRP/BCPの
策定

リアルな事業影響分析

事業影響分析はつまるところ“重要業務”を見つけ出すプロセスに当たります。しかし実際のところ、災害時に他を差し置いてでも率先してやり遂げなければならない業務は、日々の業務経験上わかっているものです。なので、改めて真なるビジネスの本質的な業務を探求するものでありません。

事業継続計画

ビジネスインパクト分析



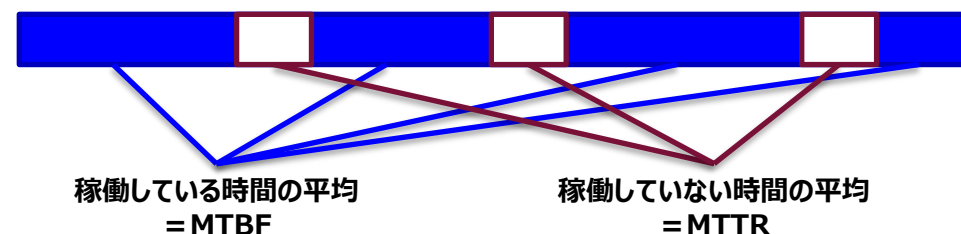
● システムの可用性

システム評価

- RASISとは、信頼性（Reliability、故障しにくいこと）、可用性（Availability、高い稼働率を維持できること）、保守性（Serviceability、障害から迅速に復旧できること）、完全性（Integrity、データの一貫性を保っていること）、安全性（Security、機密性が高いこと）の頭文字です。

稼働率による評価

- 平均故障時間（MTBF、Mean Time Between Failures）とは、新規または修理されたシステムやコンポーネントが、故障するまでの平均期間です。
- 平均修理時間（MTTR、Mean Time to Repair）とは、故障したシステムを復旧させるのにかかる平均時間です。
- 稼働率（Operation Radio）とは、システムのサービス提供稼働時間の比率を指し、可用性を示す指標となります。



稼働率を計る評価値

$$\text{稼働率 (\%)} = \frac{\text{MTBF}}{\text{MTBF} + \text{MTTR}} \times 100$$

事業継続計画

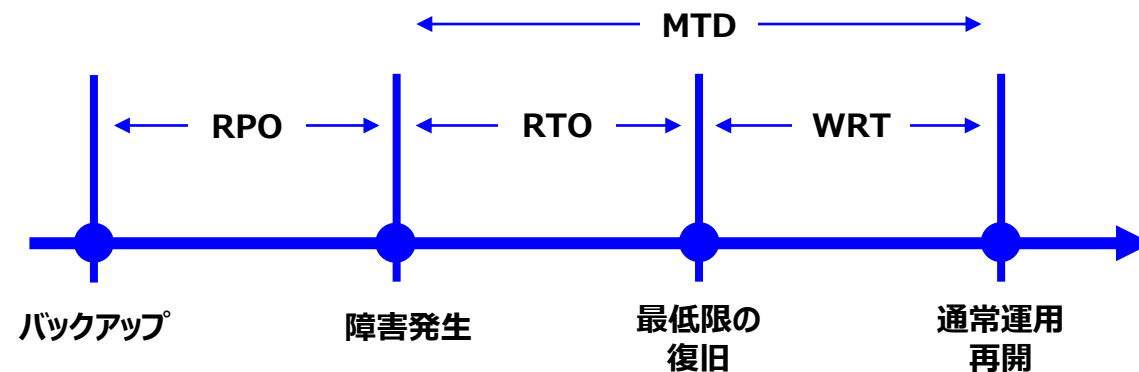
ビジネスインパクト分析



● 最大許容停止時間

事業復旧の目標値

- 目標復旧時点（RPO、Recovery Point Objective）とは、いつ時点までのデータに復旧させるかを定めた目標値です。
- 目標復旧時間（RTO、Recovery Time Objective）とは、障害発生時からクリティカルな機能（最小動作要件）をいつまでに復旧させるかを定めた目標値です。復旧と言っていますが、通常運用の時点に戻されているではありません。
- 業務復旧時間（WRT、Work Recovery Time）とは、すべてのサービスとデータを復旧し、通常運用に戻すまでの時間です。
- 最大許容停止時間（MTD、Maximum Tolerable Downtime）とは、障害が発生してから、本番環境に再投入するための設定を行う時間です。妥当なMTDとは、 $MTD \geq RTO + WRT$ であることを保証しなければなりません。



サービス復旧に関する用語の対応

表：重要度とサービスの復旧時間の目安

緊急度	復旧時間の目安
クリティカル	1-4時間
緊急	24時間
重要	72時間
通常	1週間

事業継続計画

ビジネスインパクト分析

● 最大許容停止時間

最小動作要件

- 最小動作要件（MOR、Minimum Operating Requirements）とは、重要なシステムが機能するために最低限必要な環境と接続の要件です。
- ビジネス機能を再開するために、フルスペックのシステムを必要としない場合があります。再開を早急に望まれるのであれば、必要最低限の要点を押さえておくことが大事になってきます。



試験のテクニック

現実には、アプリケーションソフトウェアの製造過程で保証された動作環境の条件を示す場合もあります。ただ、試験ではアプリケーションの動作要件の文脈ではMORが使われることは少ないでしょう。

事業継続計画

災害対策環境



●DR（Disaster Recovery）サイト

コールドサイト

- ハードウェアやバックアップはなく、復旧時にはシステムの取得、設定、アプリケーションのロードと設定が必要となります。

ウォームサイト

- リアルタイムデータではなく、以前に取得したバックアップから復元されます。
- トラフィックを手動でフェイルオーバーし、完全な切り替えと復元には4～24時間ほどかかります。

ホットサイト

- 重要なアプリケーションのみを収容し、低スペックのハードウェアを使用します。
- データはほぼリアルタイムでコピーされ、完全な切り替えには1時間以内で済みます。

ミラーサイト

- 本運用環境と完全に同一構成のサイトで、本運用環境データのリアルタイムコピーを受け取ります。
- 最もコストのかかるDRサイトですが、エンドユーザーがフェールオーバーに気づくことはないでしょう。

モバイルサイト

- コンテナやトレーラーで移動できるデータセンターです。地理的なリスクを分散することができ、低性能でも継続したシステム稼働を目指します。

表：DRサイトの分類

サイト	費用	待機 装備	データ 通信	復旧 時間	地理
コールドサイト	低	なし	なし	長	固定
ウォームサイト	中	一部	一部/フル	中	固定
ホットサイト	中～高	フル	フル	短	固定
ミラーサイト	高	フル	フル	即時	固定
モバイルサイト	高	適宜	適宜	適宜	流動

事業継続計画

災害対策環境



● 復旧体制

災害復旧チームには、災害や障害が発生した際に担当するサブチームがあります。

レスキューチーム

- ・ レスキューチームは、従業員の避難、適切な担当者への通知（コールツリー）、感染したサーバーからのネットワークの引き抜きやシステムのシャットダウン、初期の被害状況の確認などを行います。

リカバリーチーム

- ・ リカバリーチームは、DRサイトを可能な限り迅速に立ち上げ、システムを再構築する責任を負います。
- ・ 最も重要なシステムを最初に稼働させることも目指します。

サルベージチーム

- ・ サルベージチームは、プライマリーサイトが破壊された場合は新施設にインフラ、スタッフ、オペレーションを戻すことを担当します。
- ・ 重要なシステムを戻す前に新しいサイトの準備が安定していることを確認したため、重要度の低いシステムで一旦動作を確認することも判断します。

レスキューチーム



被害最小化

リカバリーチーム



早急に修復

サルベージチーム



元通り

事業継続計画

災害対策環境



● 復旧計画

運用継続計画（COOP、Continuity of Operations Plan）

- すべての危険を伴うアプローチからの緊急事態に対処するため、重要な機能が継続し、緊急時に人員とリソースが代替施設に移動されることを保証するポリシーとガイダンスを確立します。

サイバーインシデント対応・復旧（CIR、Cyber Incident Recovery）

- DDoS、ワーム、ウイルスなどのサイバーインシデントへの対応に特化した計画です。

人員緊急計画（OEP、Occupant Emergency Plan）

- 火災、ハリケーン、洪水、犯罪、テロなどの災害時に施設やスタッフ、環境をどのように保護する計画です。
- 安全と避難に焦点を当て、避難の方法、訓練の頻度、スタッフが受けるべきトレーニングについて詳しく説明しています。

ビジネス復旧計画（BRP、Business Recovery Plan）

- 破壊的なイベントから回復した後、通常の業務を再開するために必要なステップを記載した計画です。
- オペレーションを代替サイトから通常運用可能なサイトに戻すことなどが考えられます。

危機管理計画（CMP、Crisis Management Plan）

- 緊急事態や破壊的な出来事が発生した場合に、組織の経営陣の間で効果的な調整を行うための計画です。
- 災害時に人員の生命と安全および財産を直ちに保護するために、経営陣がどのような手順を踏むべきかを詳述します。

事業継続計画

災害対策環境



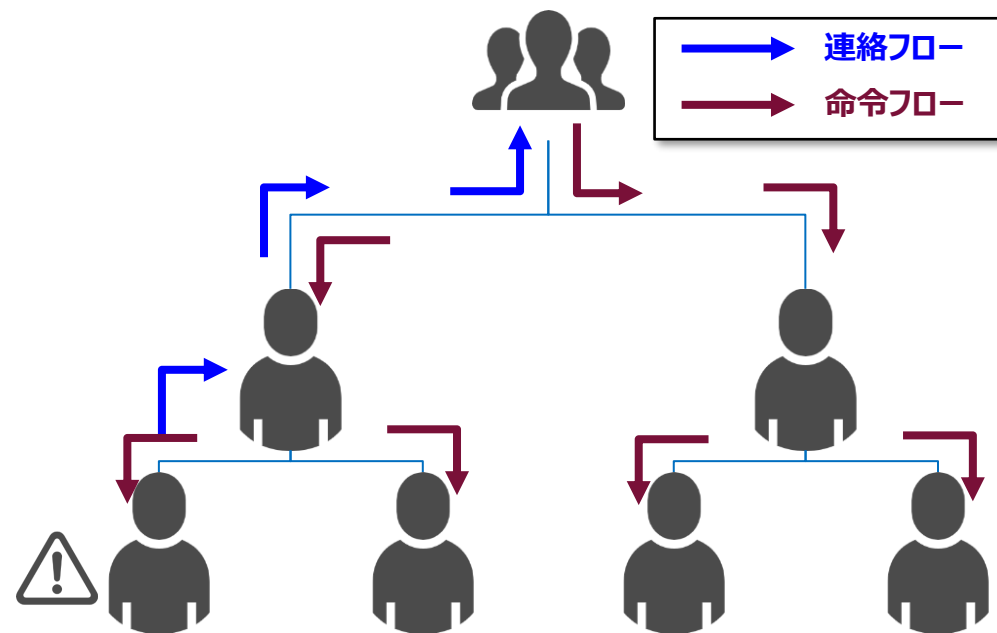
● 復旧計画

危機連絡計画 (CCP、Crisis Communications Plan)

- ・ 災害時の社内外のコミュニケーション方法の計画です。
- ・ 誰が社内の誰に何を伝えることができるか、誰が報道関係者と話すことを許可されているのかコールツリーを整理します。基本的に、インシデントを発見したスタッフはマネージャーやディレクターに連絡し、次にマネージャーやディレクターはCEOなどのシニアレベルの人に連絡します。CEOは残りのCレベルのリーダーを呼び、彼らは彼ら管轄のディレクターやマネージャーを呼び、マネージャーは管轄のスタッフを呼びます。
- ・ コールツリーはコミュニケーションプランに詳細が記載されており、ネットワークやシステムにアクセスできないことを前提に、プリントアウトしてスタッフの自宅に置いておく必要があります。

非常オペレーションセンター (EOC、Emergency Operations Center)

- ・ 緊急時に戦略的なレベルでの緊急管理または災害管理機能を担う一時的な指揮統制施設です。
- ・ 災害の影響が広範囲に及ぶ可能性があるため、地理的に遠隔に配置します。



事業継続計画

災害対策トレーニング



● 模擬試験

チェックリスト（Read-Through）

- 管理者と職能部門が計画に目を通し、復旧プロセスに必要な構成要素のリストをチェックします。

ウォークスルー（Walk-Through、テーブルトップ、構造化ウォークスルー）

- 管理者と重要な担当者のグループが集まり、復旧プロセスについて話し合うことです。
- 復旧を妨げる可能性のある認識違いや、あるいは技術的な不正確さを明らかにすることができます。

ウォークスルードリル（Walk-Through Drill、シミュレーションテスト）

- チームが災害をシミュレートし、各チームがDRPを使って対応します。
- 実際に計画が機能するのか、計画通りに動けるのかを確認します。



各項目を満たしているか？



経験値から問題がないか？



実際に機能するか？

事業継続計画

災害対策トレーニング

●ウォークスルードリル

並列処理

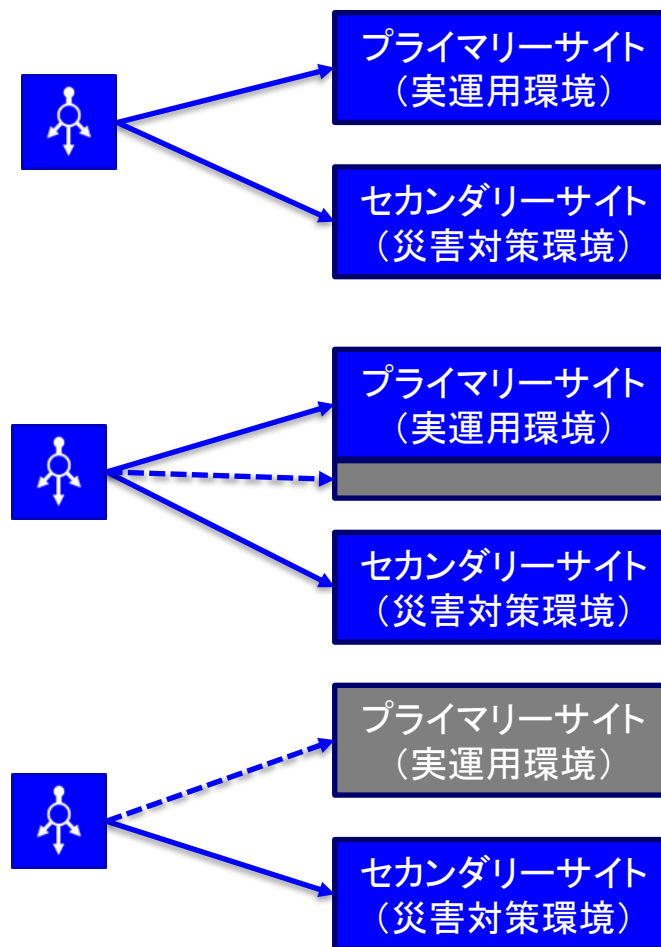
- プライマリーサイトとセカンダリーサイトで同じシステムを立ち上げ、近日のバックアップを読み込んだ2つのシステムを比較します。
- 中断するシステムがないため業務影響は出ませんが、障害時をハンドリングしてセカンダリーシステムに切り替わる試験が残されます。

部分的な中断 (Partial Interruption)

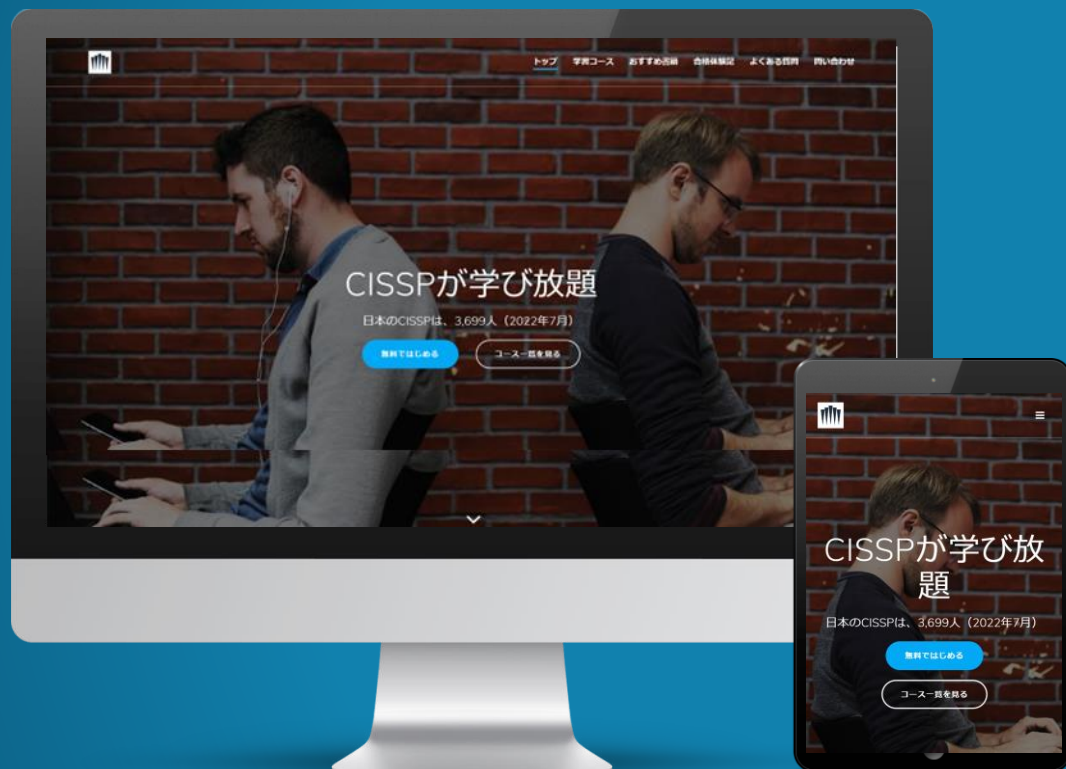
- プライマリーサイトの部分的なアプリケーションを中断し、該当のセカンダリサイトにフェイルオーバーする。
- 部分的な中断をすることで業務影響を下げるすることができます。障害時をハンドリングしてセカンダリーシステムに切り替わる試験も検証できます。

完全な中断 (Full Interruption)

- プライマリーサイトのすべてのアプリケーションを中断し、セカンダリーサイトにフェイルオーバーします。
- 完全な災害計画の検証になりますが、業務影響が出てしまうため避けられます。



PIEDPINの紹介



なぜセキュリティを学ぶのか

セキュリティの最も大きな敵は、人はあらゆるものに慣れ、そのリスクを考えなくなる習性にあります。セキュリティの学びを通して得られる貴重なものは、あらゆる事象に対して好奇心を持つことであり、それは目まぐるしい現代を生きるのに大いに役立つでしょう。

- EASY DESIGN
- SUPER EFFICIENT
- EVERYWHERE

PIEDPINを選ぶ理由



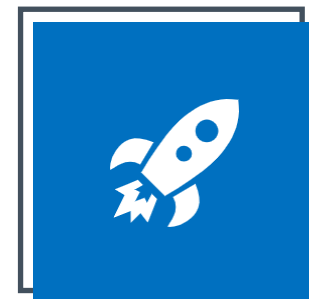
**EASY
DESIGN**

日本語で学べる



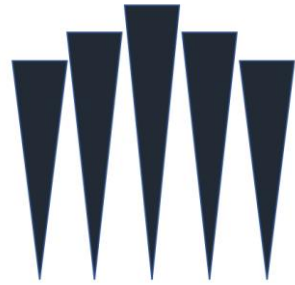
**SUPER
EFFICIENT**

わかりやすい説明



EVERYWHERE

どこからでも学べる環境



THANK YOU

CISSP for BEGINNER